



Anomaly Detection and Cyber Attacks Mitigation: Part 1

Dr. Alfian Presekal, Dr. Alex Stefanov

EE4410 - Cyber Security of Power Grids

Faculty of Electrical Engineering, Mathematics and Computer Science, **TU Delft**

Lecture 7 on June 3, 2025

Disclaimer & Ethics

1. **All information provided in the course is for educational purposes only.** The lecturer(s) and teaching assistant(s) are not responsible for any misuse of the information.
2. The course does not promote and is strongly against illegal activities such as unethical hacking, cracking and piracy.
3. **Do not attempt to violate the law with anything contained in the course.** Do not abuse the material provided and be responsible.
4. By participating in the course, **you (student) must accept that you will only lawfully use the material and knowledge you got from this course.**
5. Any actions and / or activities related to the material contained within this course are solely your (student) responsibility. **The misuse of the information in this course can result in criminal charges brought against the persons in question.**
6. The lecturer(s) and teaching assistant(s) will not be held responsible in the event any criminal charges are brought against any individuals misusing the information from this course to break the law.

Outline

1. IT-OT Network Segmentation, Intrusion Detection and Prevention Systems
2. Advanced Persistent Threats on Power Grids
3. Cyber-Physical System Model
4. Traffic Dispersion Graph



IT-OT Network Segmentation, Intrusion Detection and Prevention Systems

IT-OT Network Segmentation

- Common security recommendations & best practices
 - Identify what systems need to be protected
 - Separate the systems logically into functional groups
 - Implement a defense-in-depth strategy around each system or group
 - Control access into and between each group
 - Monitor activities that occur within and between groups
 - Limit actions that can be executed within and between groups
 - Use cyber kill chain to analyse and protect against cyber attacks

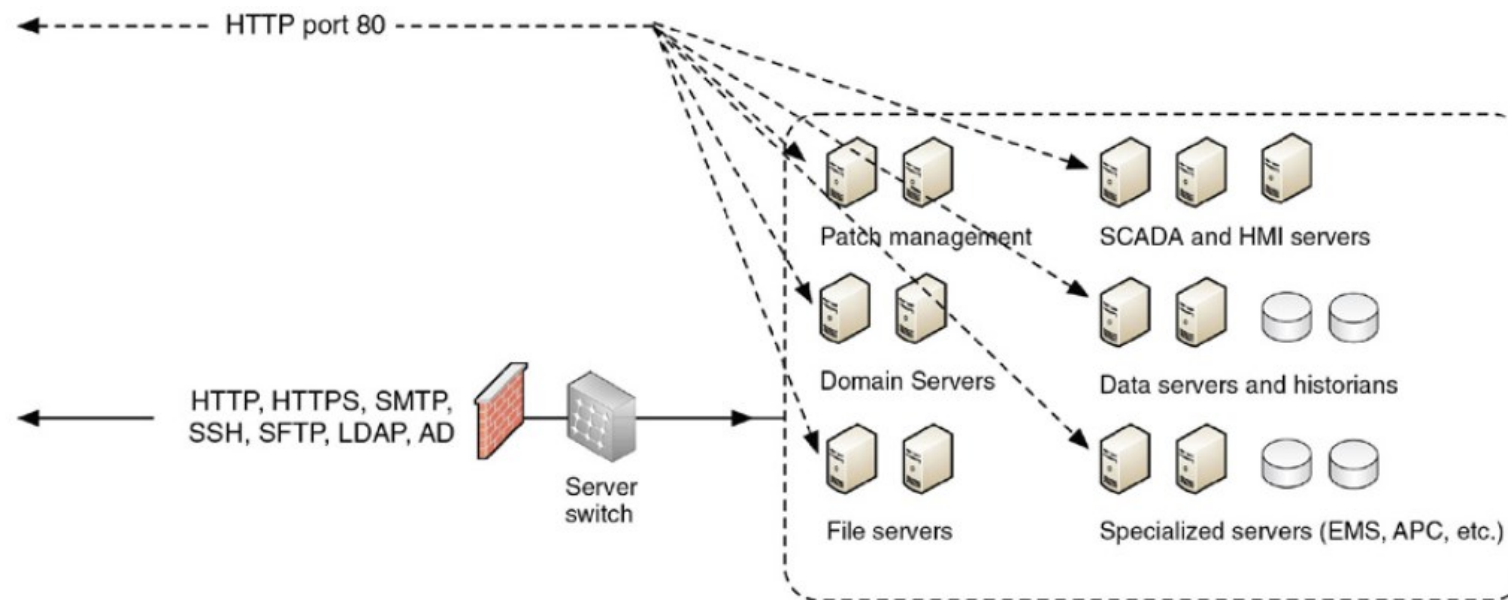


Source: Getty Images/iStockphoto

IT-OT Network Segmentation

- Network segmentation / isolation of systems

- Separation of assets into functional groups allows specific services to be tightly locked down and controlled
- Easiest method of reducing attack surface that is exposed to potential threat actors
- Disable all unnecessary services and communication ports to eliminate most known / unknown vulnerabilities



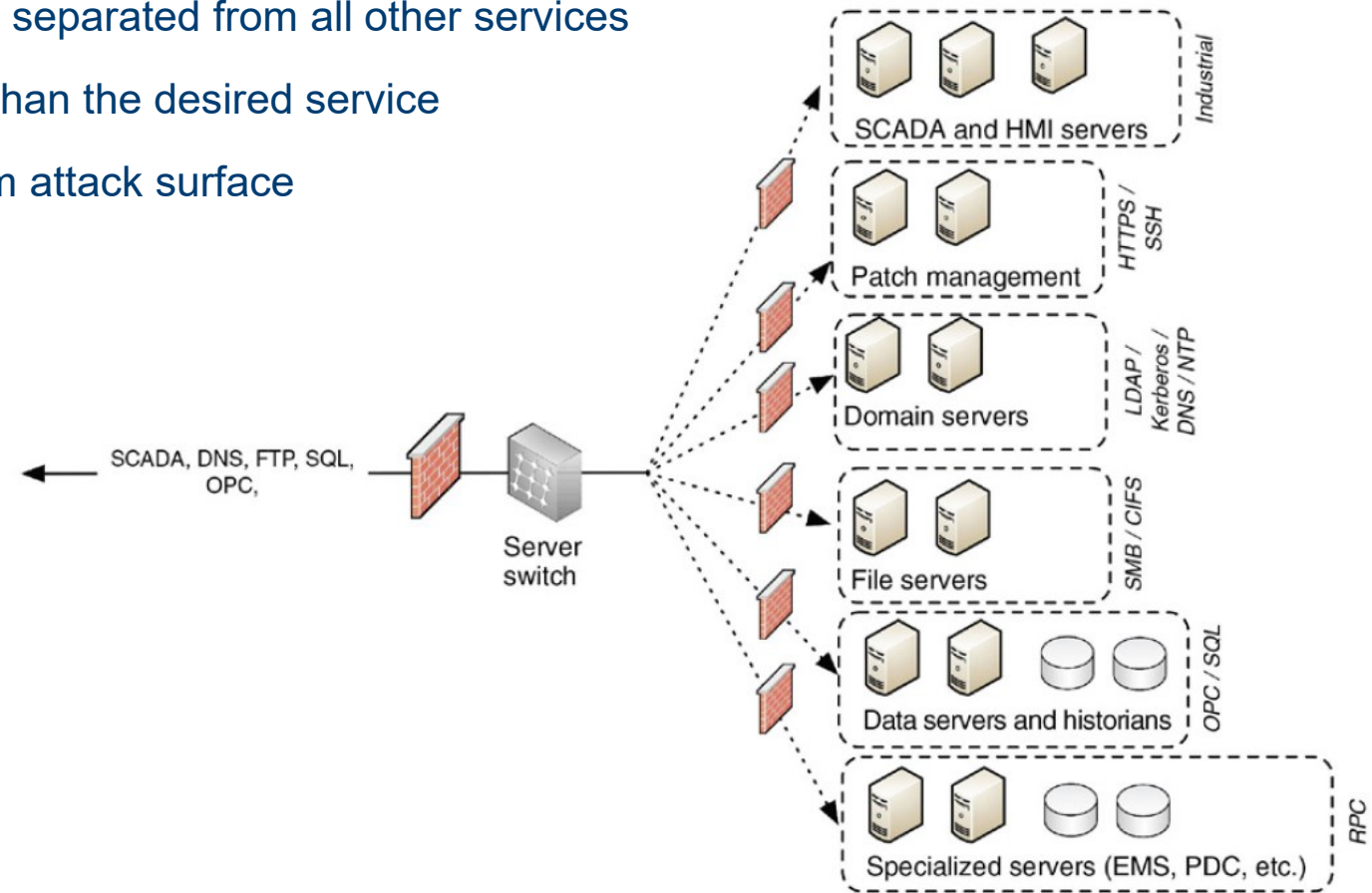
Placing all services behind a common defense provides a broader attack surface on all systems

[Knapp, E. & Langill, J. (2015). Industrial network security: securing critical infrastructure networks for smart grid, SCADA, and other industrial control systems (Second Ed). Syngress]

IT-OT Network Segmentation

- Network segmentation / isolation of systems

- Each specific service is grouped functionally and separated from all other services
- Firewall is configured to disallow anything other than the desired service
- Separation into functional groups reduces system attack surface



IT-OT Network Segmentation

- Network segmentation / isolation of systems

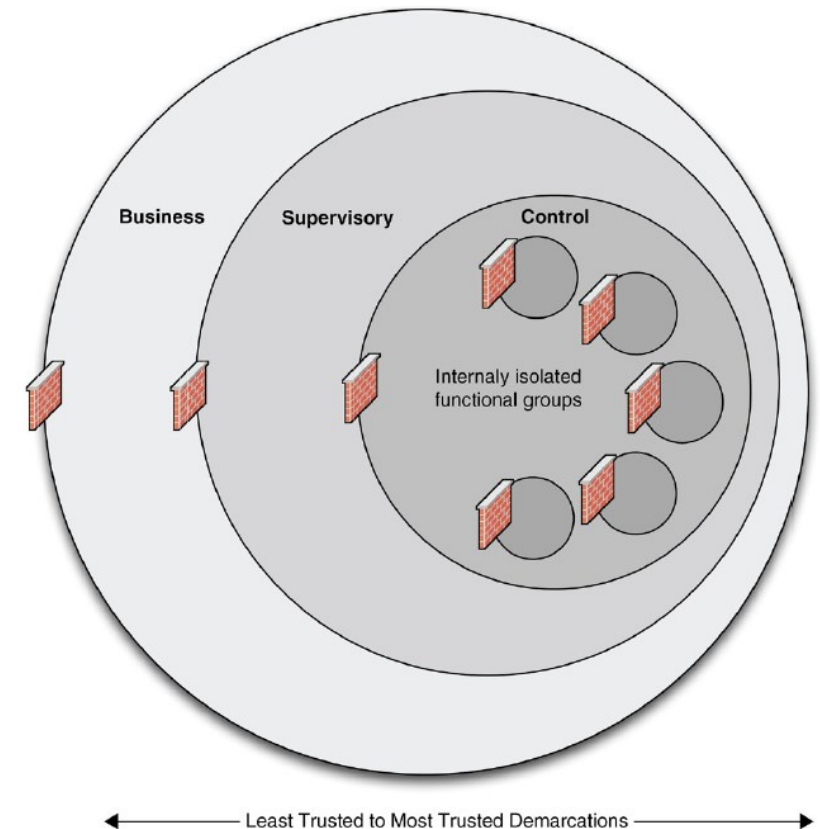
- A layered approach to functional and topological isolation can greatly improve the defensive posture of the network

- Methods of securing zones

- ✓ Dedicated firewalls, intrusion detection and prevention systems (IDPS)
- ✓ Application content filters, access control lists

- Caution

- ✓ Control communications in both directions through a firewall
- ✓ Not all threats originate from outside to inside (less to more trusted networks)
- ✓ Open, outbound traffic policies can facilitate insider attacks to
 - Enable the internal spread of malware
 - Enable outbound command and control capabilities
 - Allow for data leakage or information theft



IT-OT Network Segmentation

- Defense in depth

- Defense-in-depth strategy is required by all standards, regulations and recommendations
- Best practice: deploy layered or tiered defensive strategy
- Common defense-in-depth model is depicted
- Maps logical defensive levels to security tools & techniques

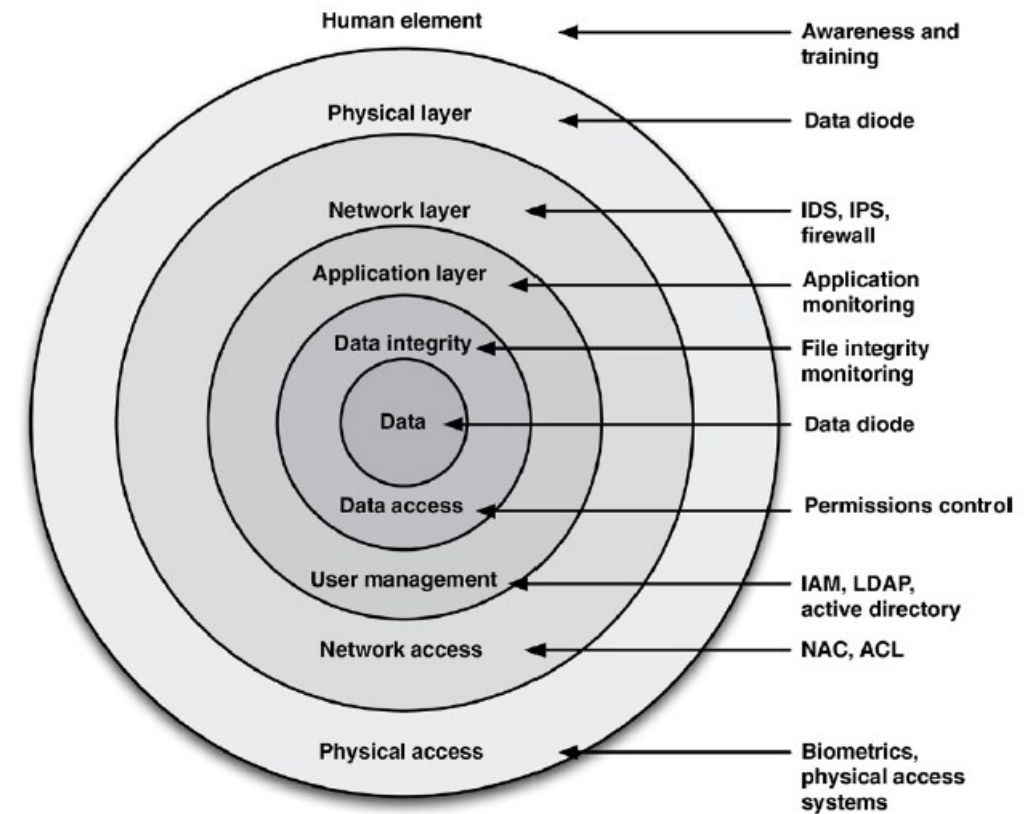


TABLE I.4 An Overview of Typical Security Devices/Software

Name	Security check	Action taken
Firewall	TCP/IP packet header inspection	Block
Intrusion Detection System (IDS)	TCP/IP packet header and content inspection	Alert
Intrusion Prevention System (IPS)	TCP/IP packet header and content inspection	Block and alert
VPN: SSL/TLS	Authentication, encryption and integrity	Communication protection
VPN: IPsec	Authentication, encryption and integrity	Communication protection
Network access control (NAC)	Host health inspection, authentication, encryption and integrity	Access control

VPN: Virtual Private Network

SSL: Secure Sockets Layer

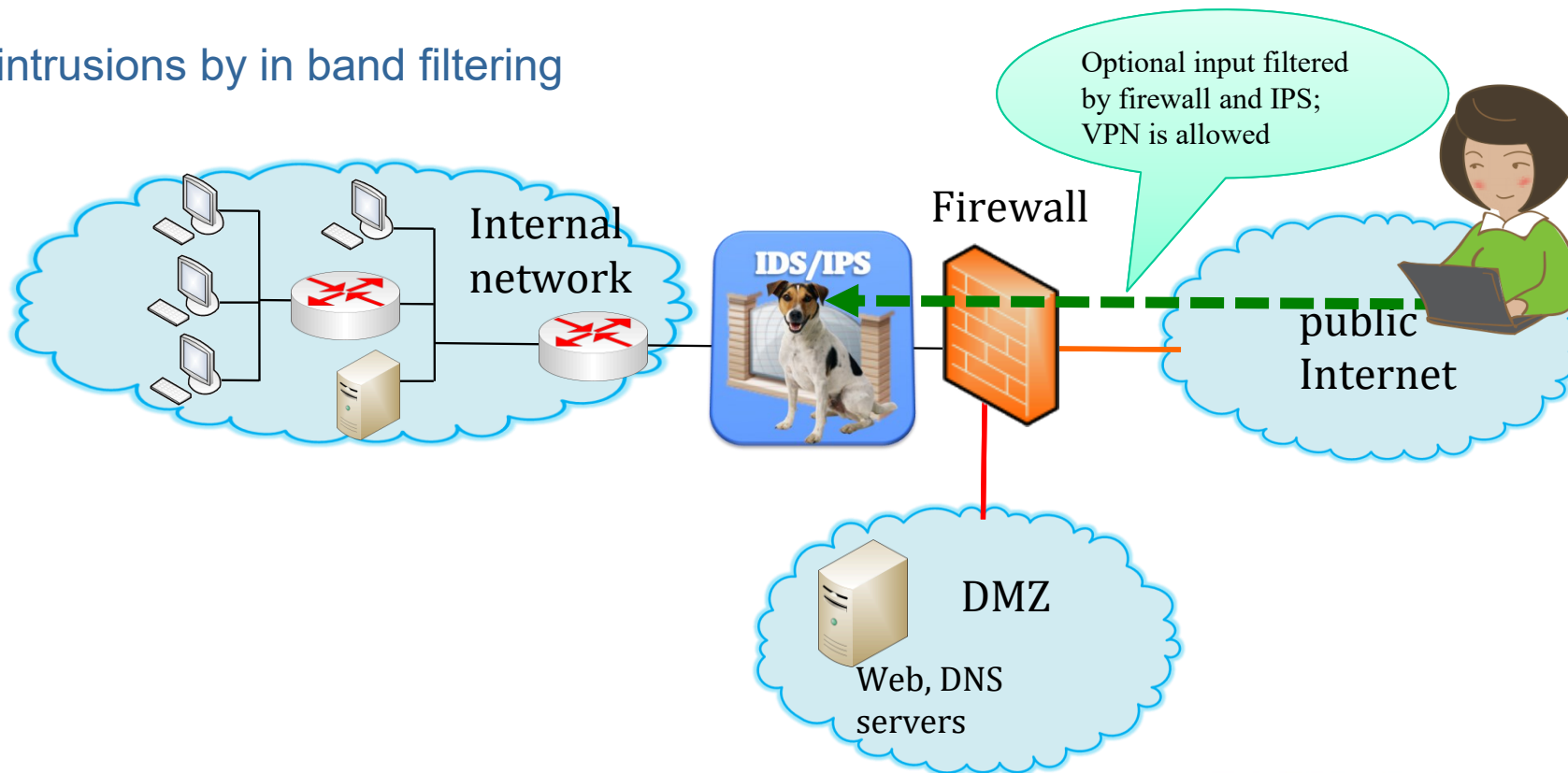
TLS: Transport Layer Security

IPsec: Internet Protocol Security

[Wu, Chwan-Hwa, & Irwin, J. David. (2013). Introduction to computer networks and cybersecurity. CRC Press.]

Intrusion Detection/Prevention Systems (IDS/IPS)

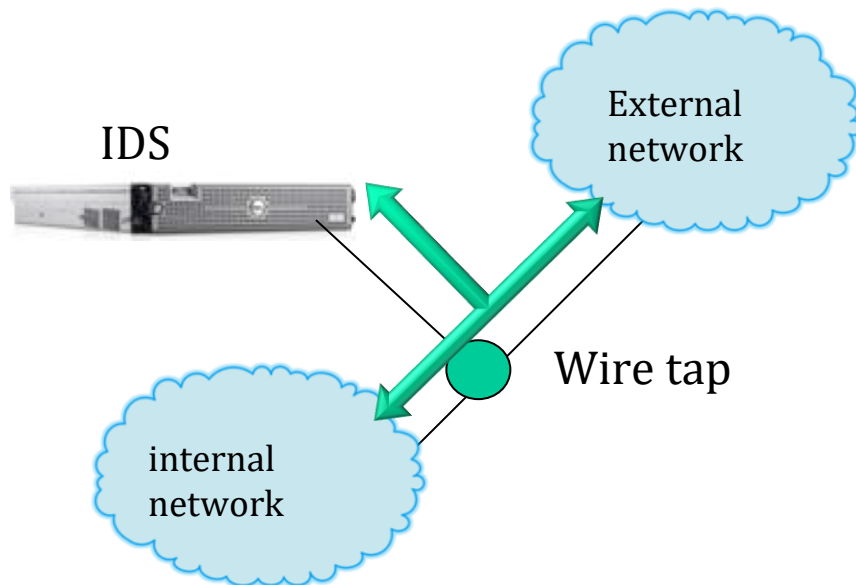
- Deep packet inspection (payload)
- IDS: report intrusions by out of band detection
- IPS: block intrusions by in band filtering



Intrusion Detection/Prevention Systems (IDS/IPS)

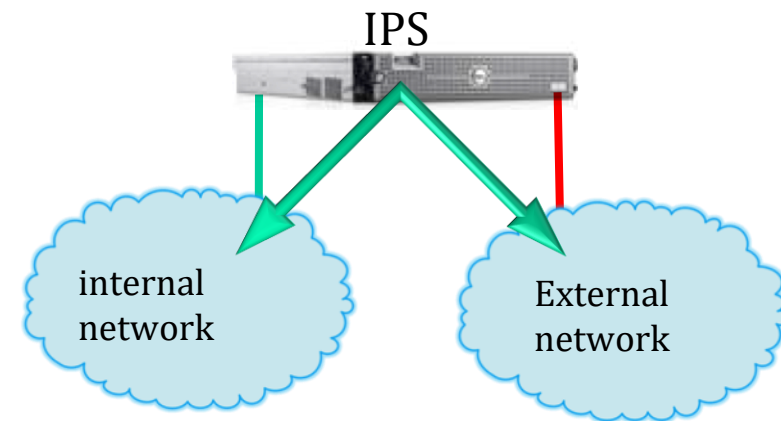
- IDS: out of band

- An IDS false positive is an alert that did not result in an intrusion
- An IDS false positive causes a security analyst to expend unnecessary effort
- No interference with traffic

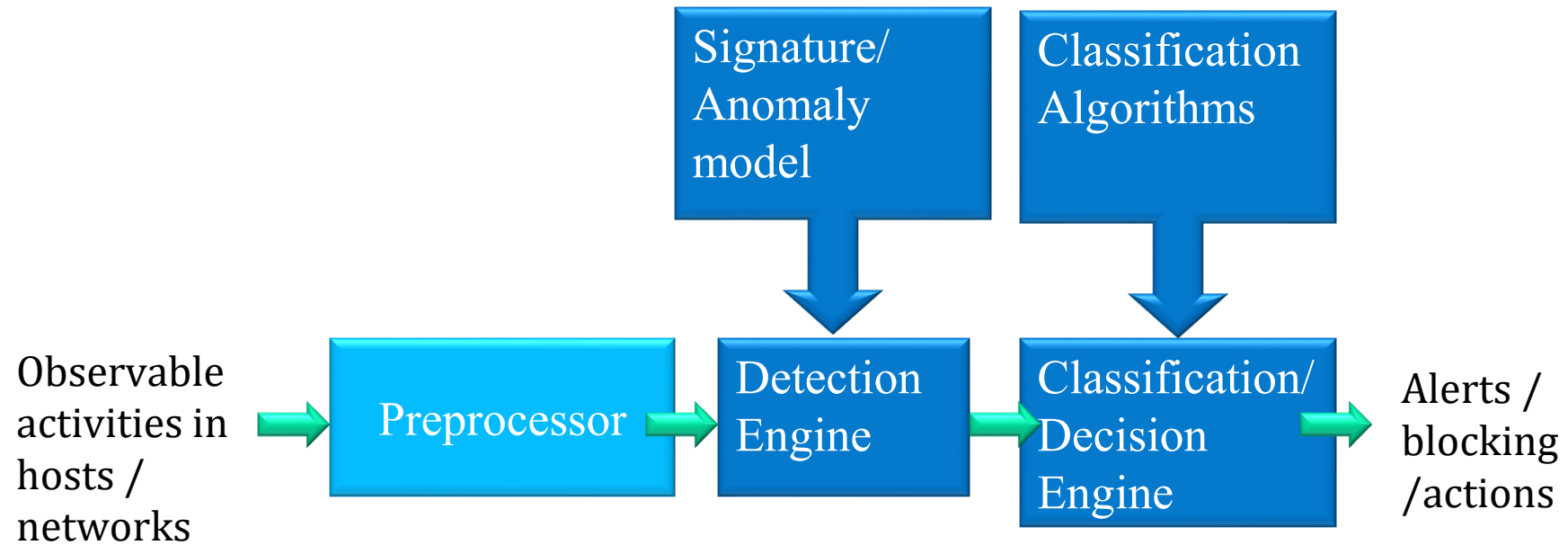


- IPS: in band

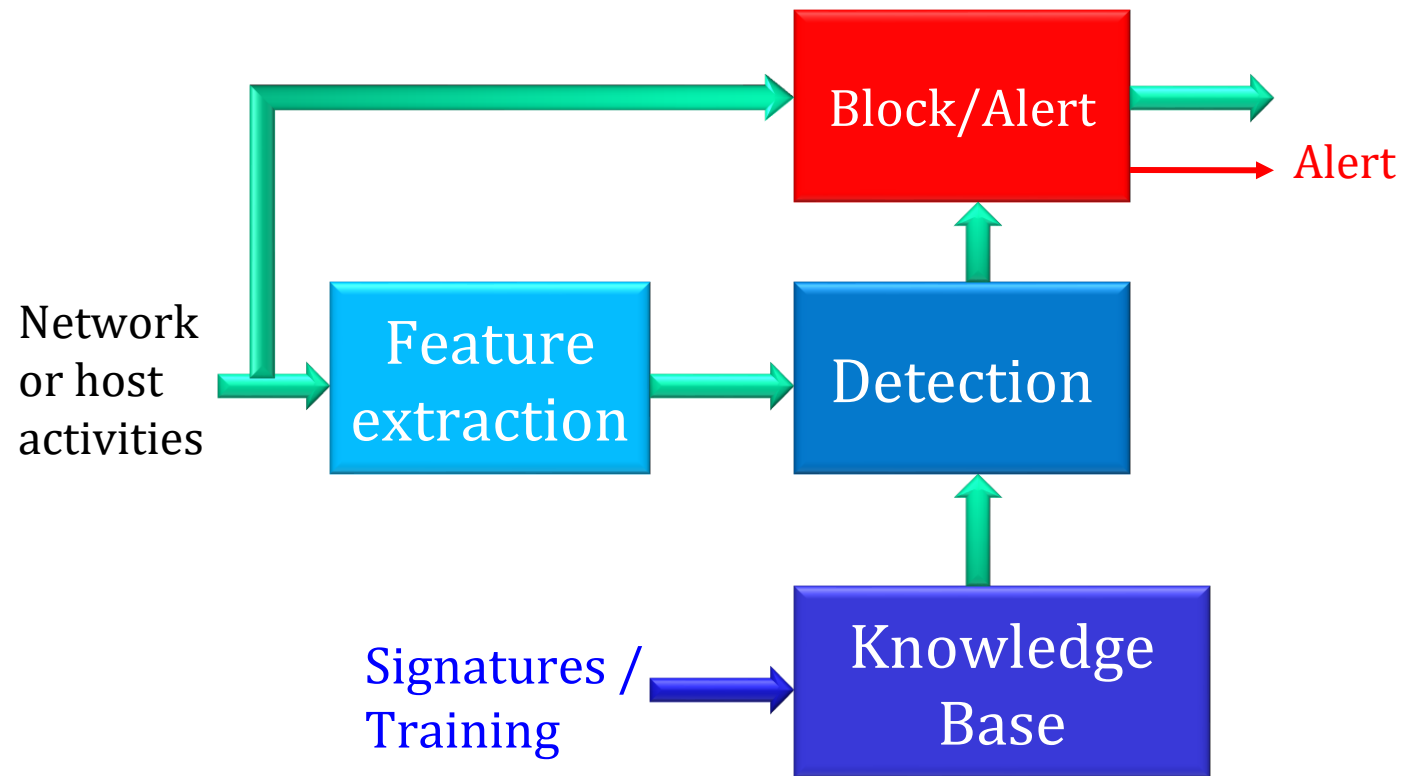
- When an IPS has a false positive, legitimate traffic will be blocked
- IPS cannot have false positives
- To match the line speed, IPS hardware requirement is higher



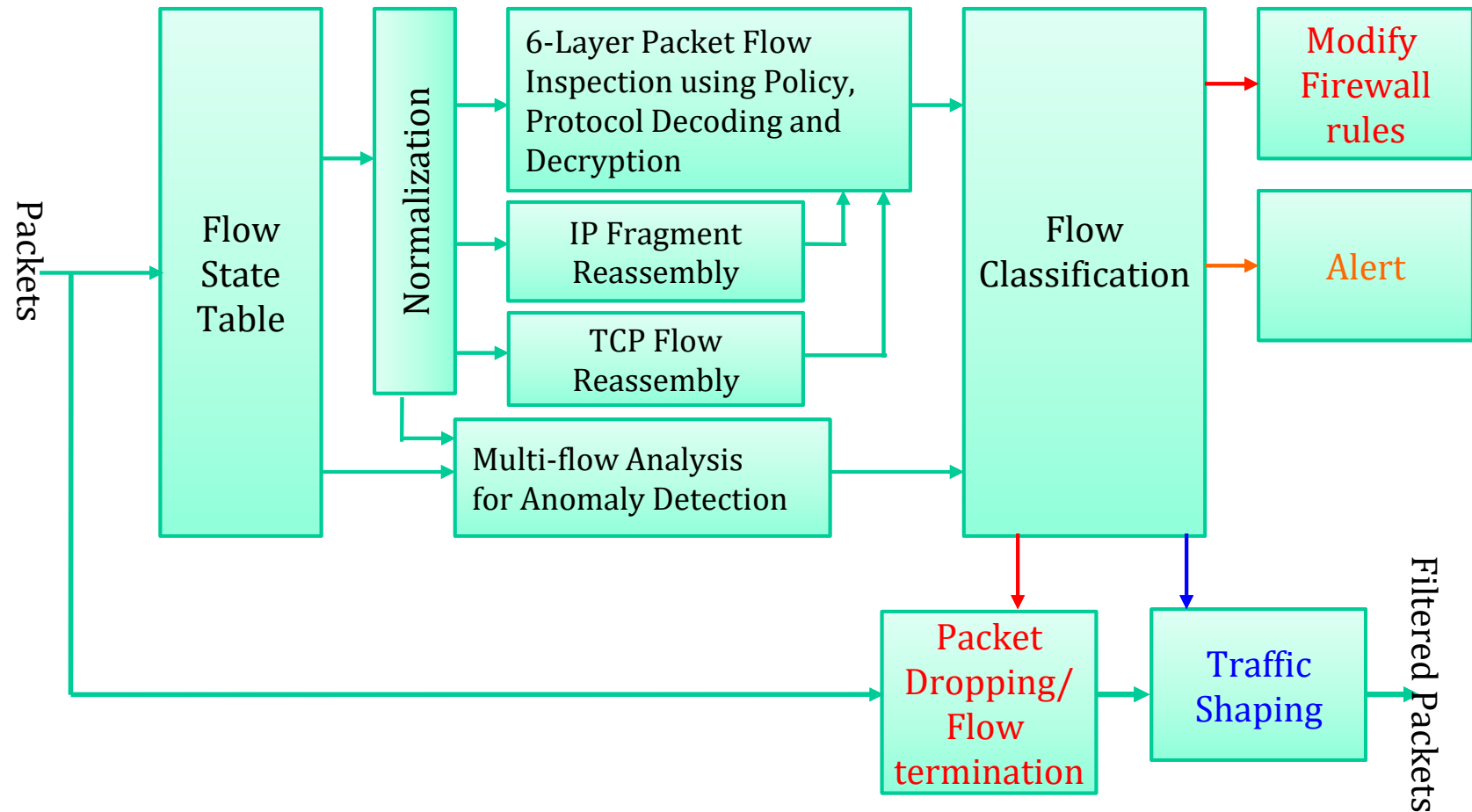
Intrusion Detection/Prevention Systems (IDS/IPS) Block Diagram



Intrusion Detection/Prevention Systems (IDS/IPS) Function Blocks



Network-based IPS Block Diagram



Activities Monitored by IDS/IPS

- Monitors many activities and can capture an occurrence of any event that is deemed to be a security concern
- Some typical intrusions include
 - Reconnaissance
 - Patterns of specific commands in application sessions
 - ✓ e.g., a successful remote login session should contain authentication commands
 - ✓ Login and location frequency
 - Content types with different fields of application protocols
 - ✓ e.g., the password for an application must be 7-bit ASCII of 8 to 64 allowed characters to avoid buffer overflow and SQL injection
 - Network packet patterns between protected servers and the outside world
 - ✓ Client application, protocol and port, volume, and duration
 - ✓ Rate and burst length distributions for traffic
 - Privilege escalation, malware and denial of service attacks

Intrusion Detection/Prevention Systems (IDS/IPS)

- Host-based IDS/IPS
 - Monitor/block activity on a single host
 - Advantage: better visibility into behavior of individual applications running on the host
- Network-based IDS/IPS (NIDS/NIPS)
 - Often placed behind a router or firewall that is the entrance of a critical asset
 - Monitor traffic, and examine packet headers and payloads
 - Advantage: single NIDS/IPS can protect many hosts and detect global patterns
- IDS needs to detect a substantial percentage of intrusions with few false alarms
 - If too few intrusions detected (false negatives): no security
 - If too many false alarms (false positives): ignore
 - Existing systems are improving

Intrusion Detection/Prevention Systems (IDS/IPS) Approaches

- Behavior-based detection

- Statistics-based anomaly detection

- ✓ Threshold independent of user
- ✓ Profile per user
- ✓ Computationally expensive

- Rule-based suspicious behavior detection

- ✓ Behavior is commonly associated with a type of attack, such as buffer overflow

- Pro: May detect zero-day attacks

- Con: Usually higher false positive rate

- Signature-based detection

- Detect patterns of specific known exploits and vulnerabilities

- ✓ Exploits: patterns of codes, scripts, registration key modification, RET addresses of buffer overflow exploits
- ✓ Vulnerabilities: traffic or requests to a known vulnerability
 - Vulnerability-based signatures
 - Once a new vulnerability is disclosed, researchers develop signatures that anticipate the nature of yet-to-be-created threats

- Signature captures

- Pro: Usually lower false positive rate

- Con: May not detect zero-day attacks

Intrusion Detection/Prevention system

- Behavior-based detection

- The behavior is a characterization of the state of the protected system
- A baseline of normal behavior is developed, and when an event falls outside that norm, it is flagged and logged
- Profile: information about what is normal and what is not
 - ✓ Consisting of a comprehensive list of parameters and values for the target being monitored
- Due to the ever-changing nature of network traffic, applications and exploits , false positives may occur



Source: towardsdatascience.com

[Wu, Chwan-Hwa, & Irwin, J. David. (2013). Introduction to computer networks and cybersecurity. CRC Press.]

Intrusion Detection/Prevention system

- Adaptive and self-learning profile

- Adaptive profiles can account for normal network changes to avoid raising false alarms
- Self-learning is critical to ensure wide and successful deployment of anomaly-based detection mechanisms
 - ✓ It is very difficult for security analysts to manually set the profiles because of the complexity of dynamically changing traffic statistics
 - ✓ Need to apply anomaly-based detection at various levels of traffic aggregation to achieve the most accurate protection



Source: towardsdatascience.com

[Wu, Chwan-Hwa, & Irwin, J. David. (2013). Introduction to computer networks and cybersecurity. CRC Press.]

Signature vs. Behavior

- Signature-based detection
 - Clearly indicates the detected attack method
- Behavioral-based alerts
 - Attack type
 - Behavioral rule that was violated, such as port scan
 - Statistical profile that was violated
- Behavioral protection can not identify the specific attack or exploit that was blocked
 - Require security administrator to decipher clues given by the behavioral rule to determine which attack was actually attempted
 - Acceptable for new and unknown attacks
 - But established threats and known exploits should be easily identifiable
- Deciphering information about each attack reported by a behavioral-only system becomes unmanageable for a large number of hosts



Advance Persistent Threats on Power Grids

Cyber Attack on Power Grids

- Electrical power grids are vulnerable to cyber attacks:
 - On December 23, 2015, a cyber attack was conducted on the power grid in Ukraine that resulted in a power outage, affecting 225,000 customers
 - On December 17, 2016, a cyber attack was targeted the Ukrainian power grid resulting in a power outage in the distribution network, where 200 MW of load was left unsupplied
 - On October 2022, Sandworm malware disrupted the Operational Technology (OT) systems in the Ukrainian power grid, leading to a power outage



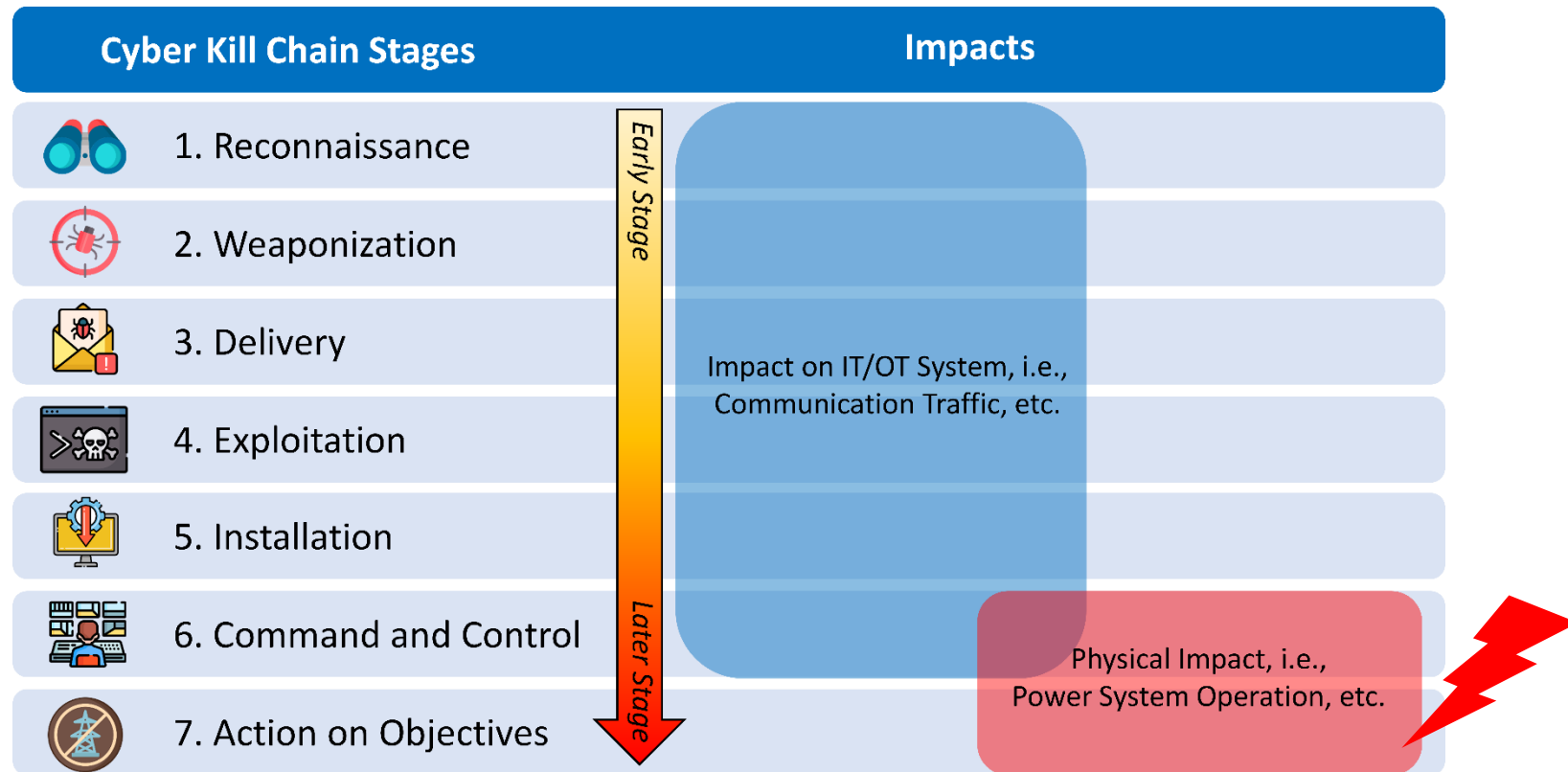
Advanced Persistent Threat Challenges

- In the cyber attacks in Ukraine, the adversaries remain undetected as an Advanced Persistent Threat (APT) for more than six months
- The final stages caused power outages in a matter of minutes

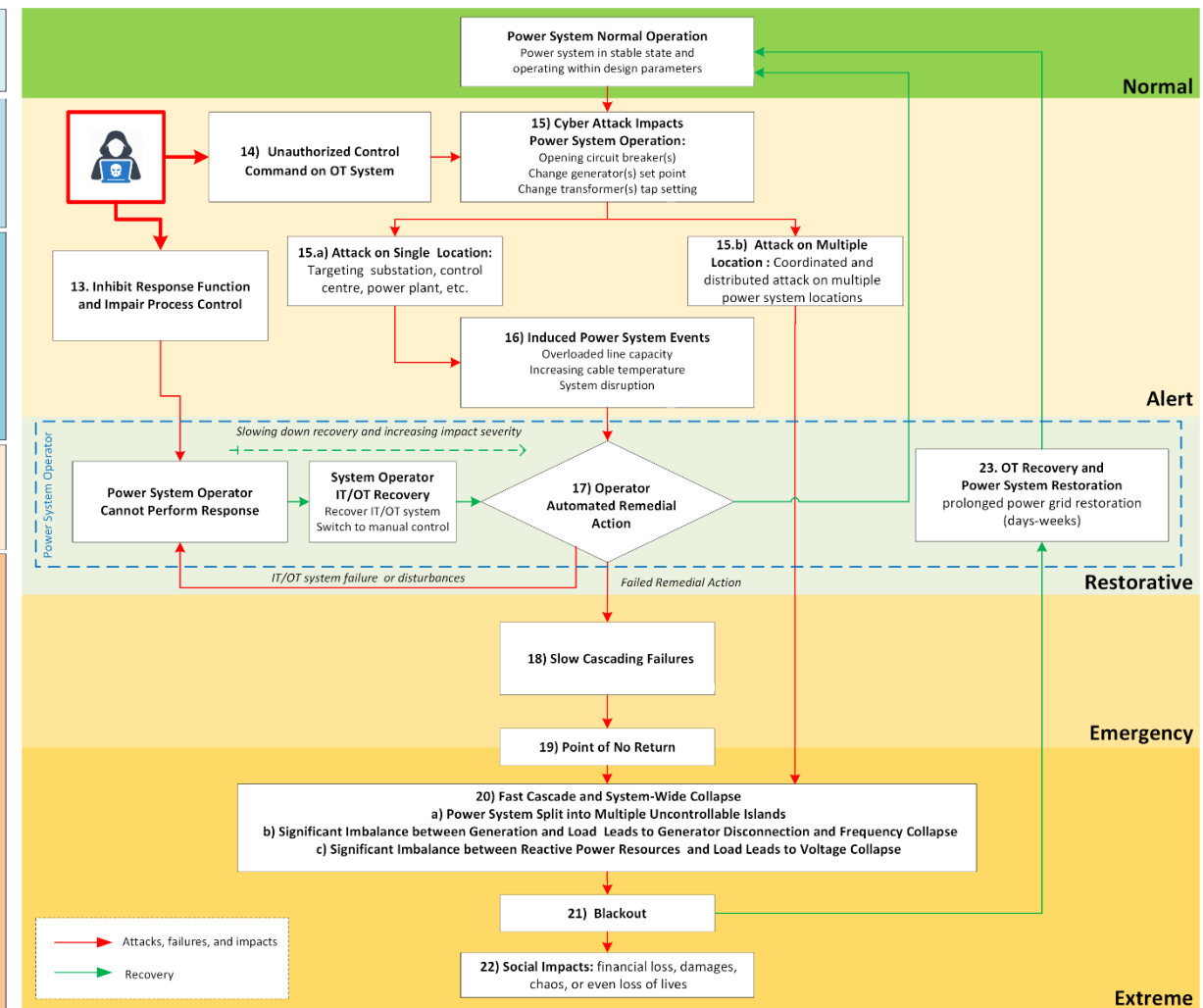
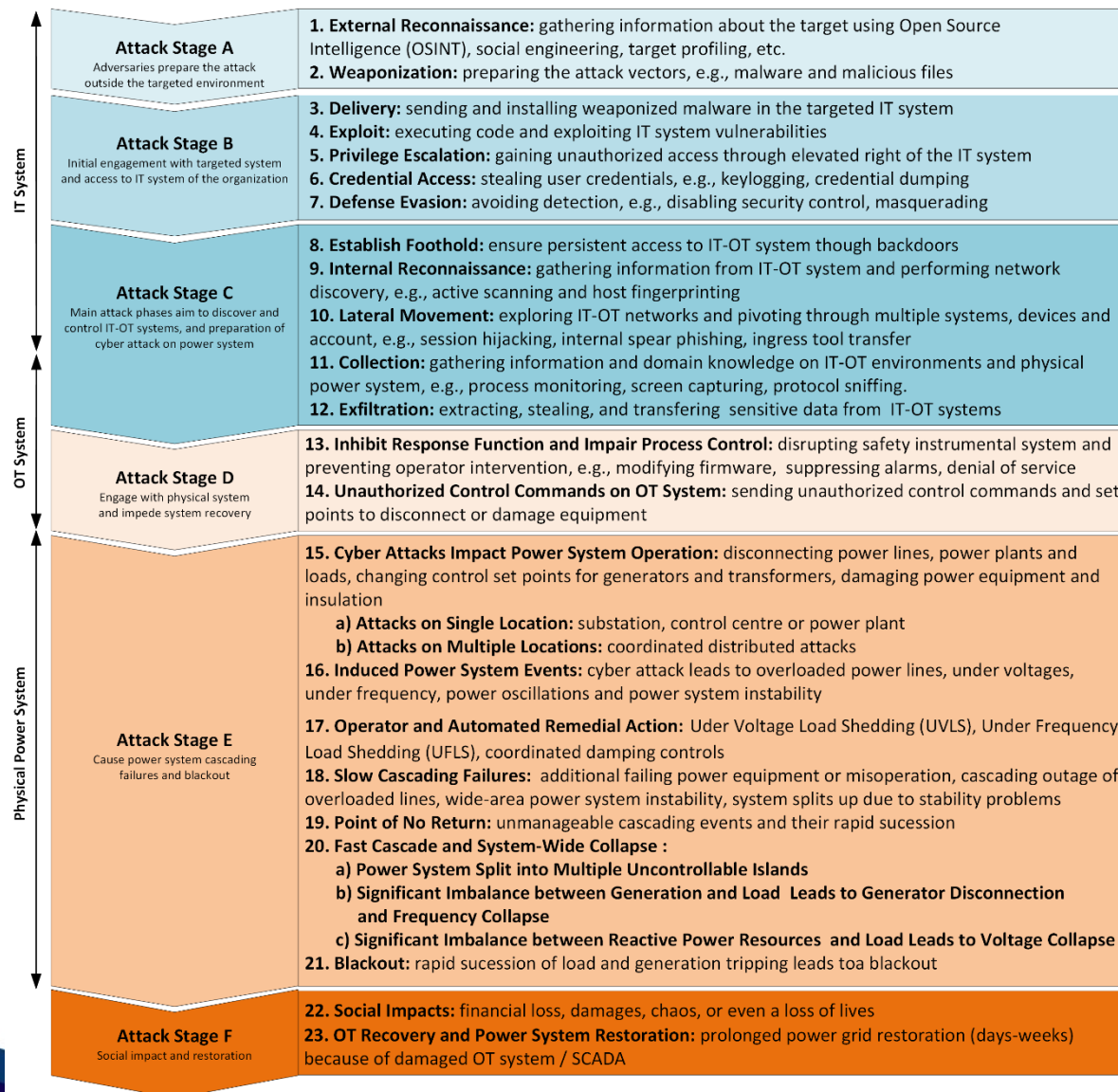


Cyber Kill Chain

- Existing attack detections are based on power system measurement anomalies that occur when an attack is successfully executed at the later stages of the cyber kill chain



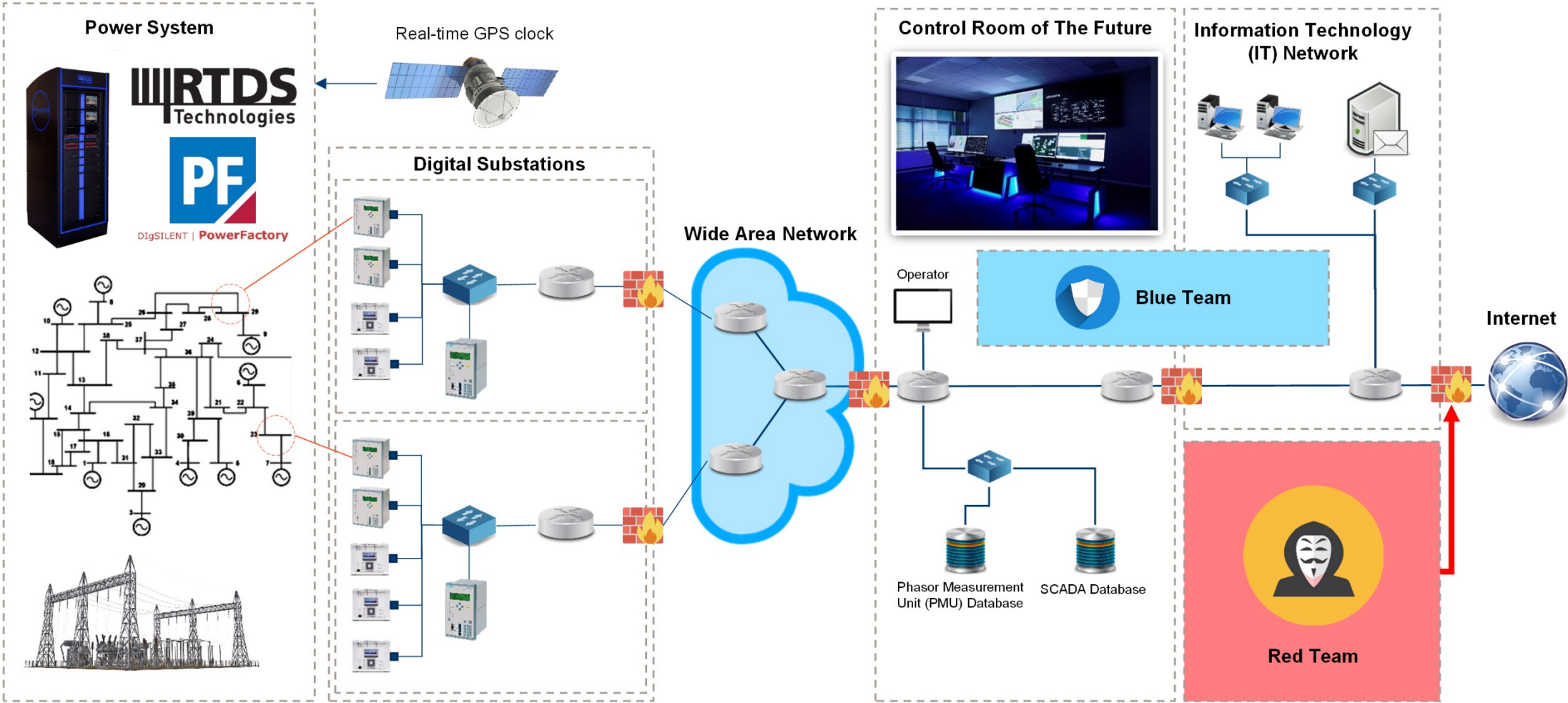
Advanced Cyber-Physical Power System Kill Chain



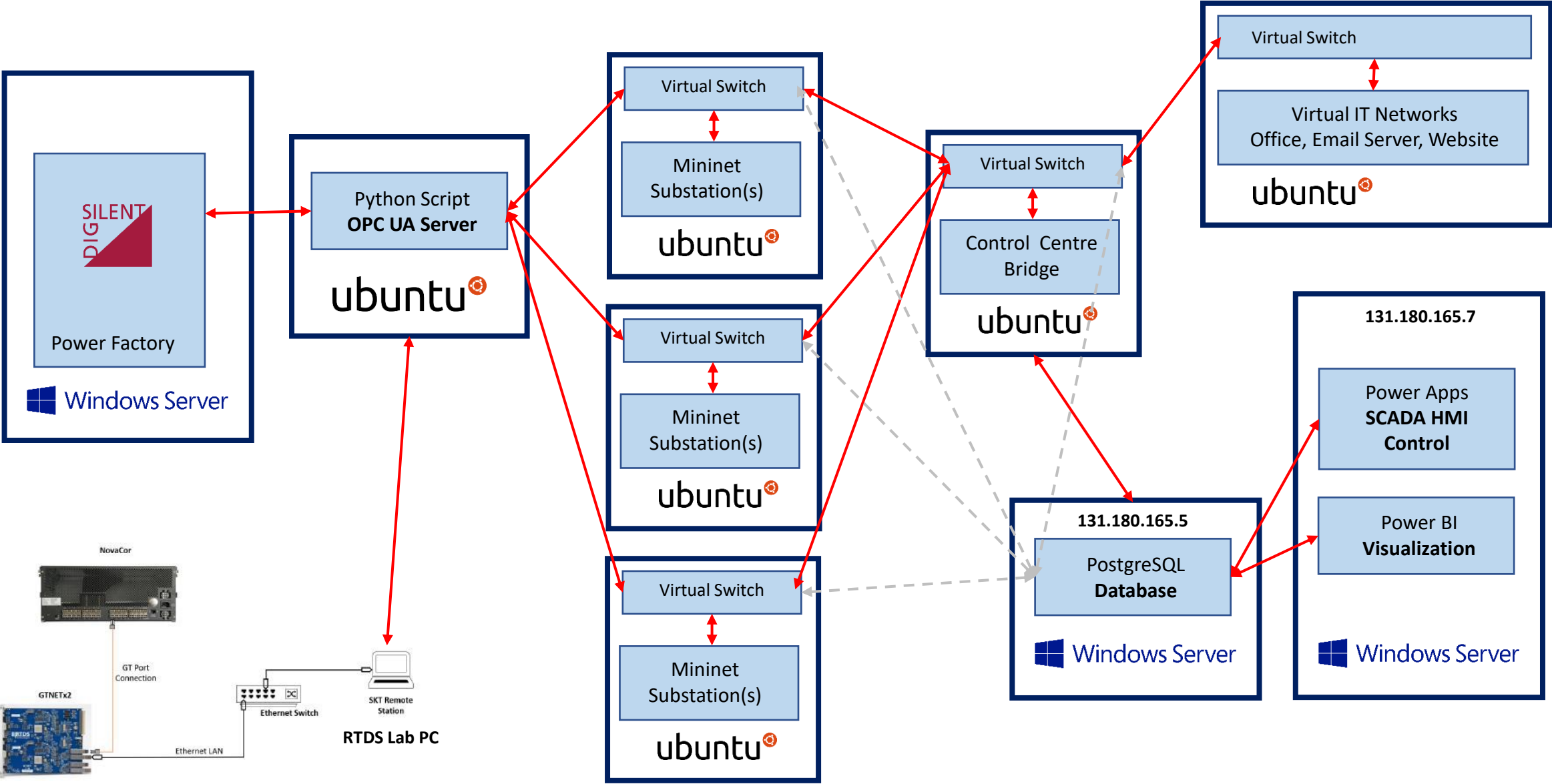


Cyber-Physical System Model

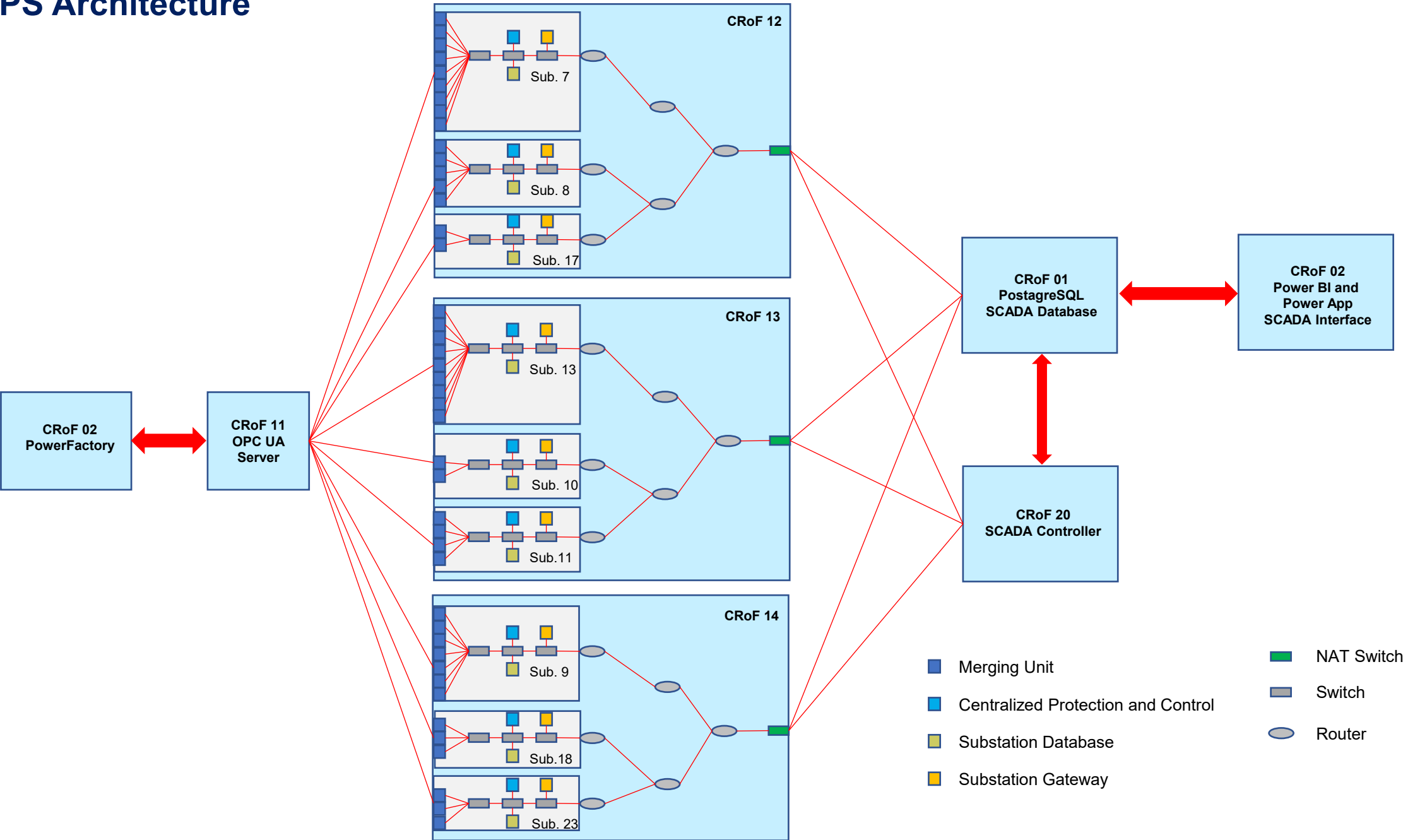
Cyber-Physical System Model



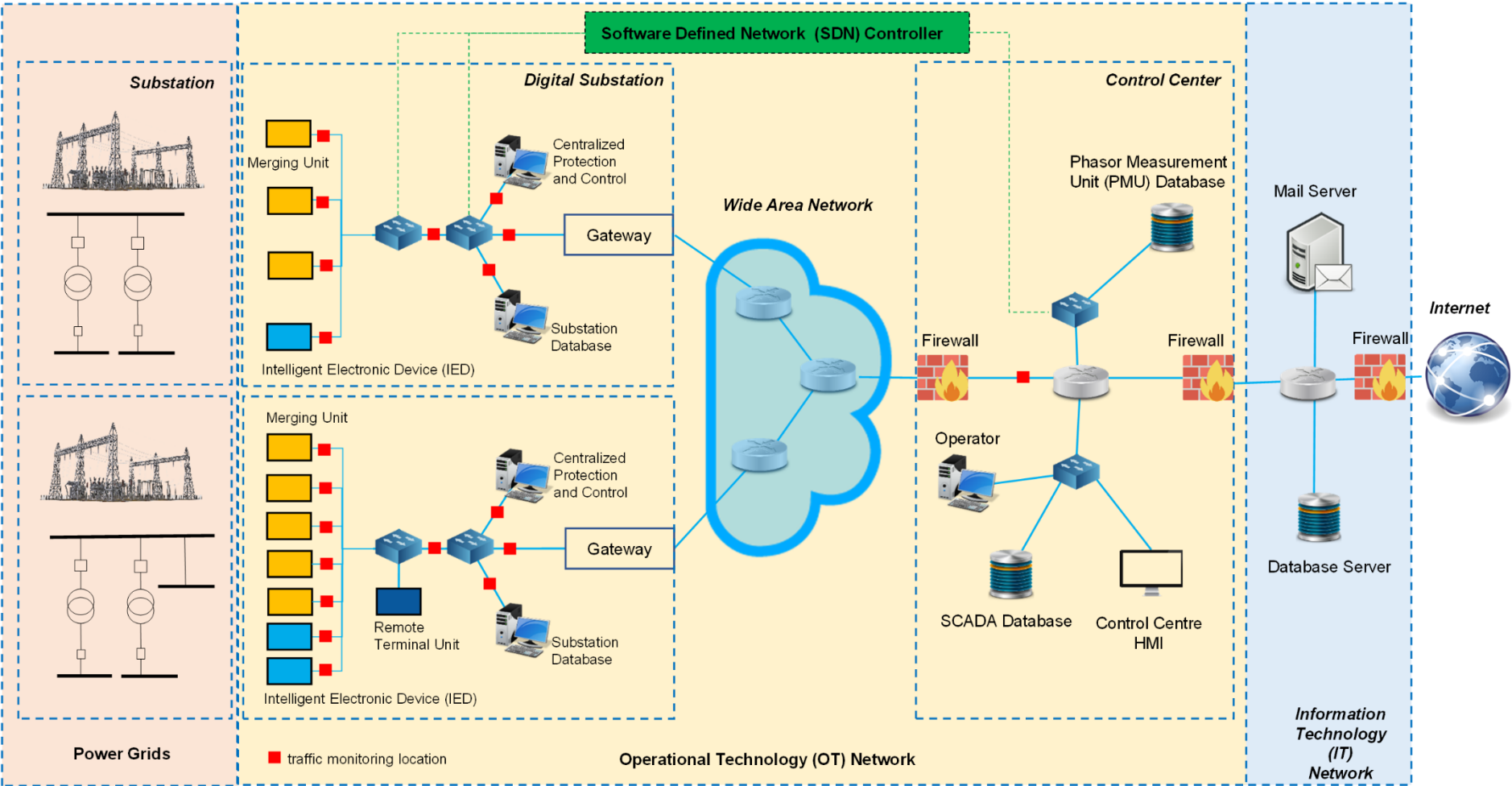
Implementation of Cyber-Physical System Co-Simulation in Virtual Machines



CPS Architecture

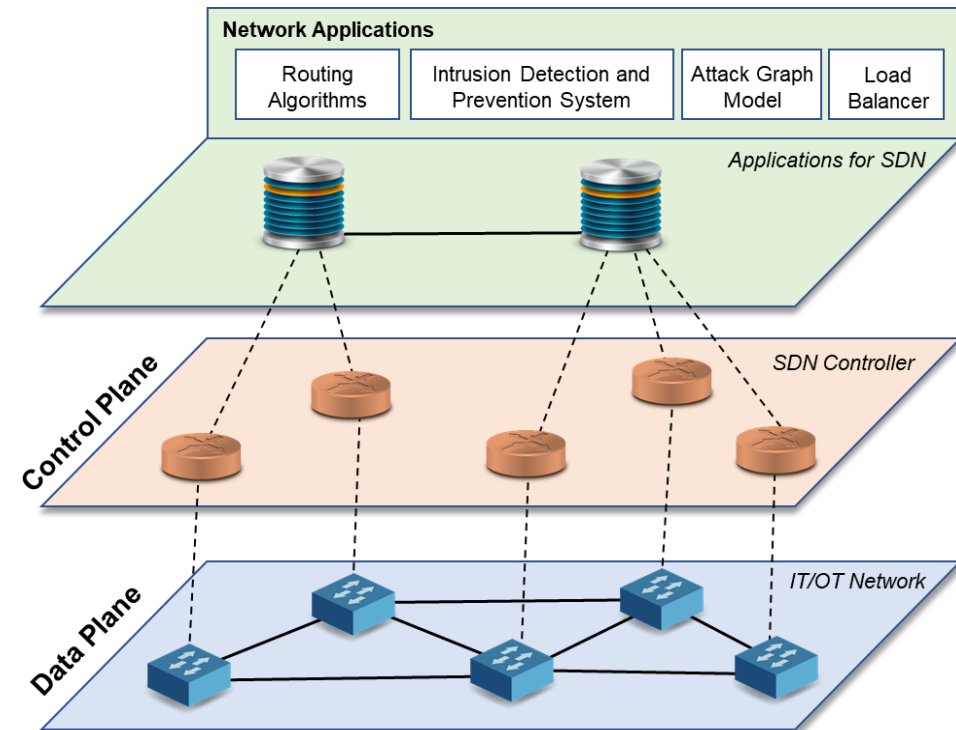


Cyber-Physical System Model of the Power Grid with SDN



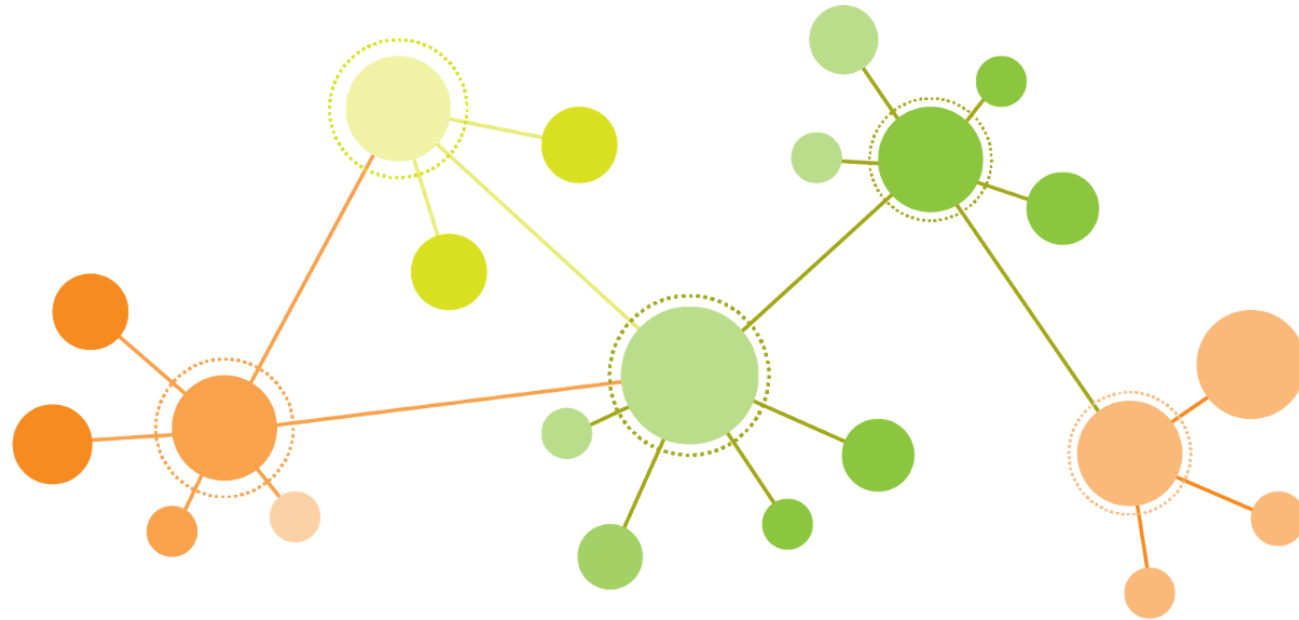
Software Defined Networking

- SDN is a networking paradigm based on network virtualization and segregation of data and control planes
- SDN helps operators manage the entire network consistently and holistically, regardless of the underlying network technology:
 - Separation of the network control plane from IT/OT network
 - Control plane controls several devices
 - Designed to improve network flexibility management



Challenges from SDN Implementation in CPS of Power Grid

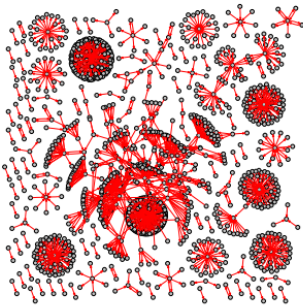
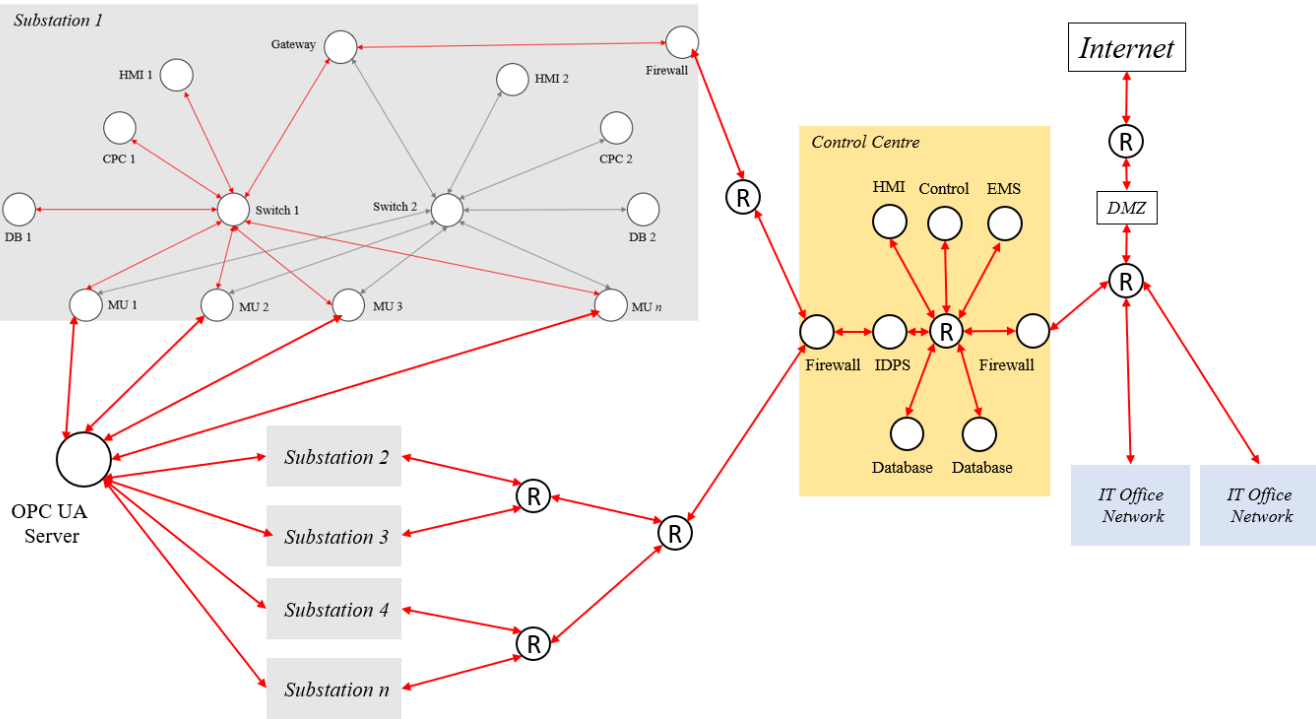
- Existing SDN applications for cyber-physical systems are not focused on cyber security of OT networks
- The current proposed implementations are mainly based on packet flow rules
- SDN implementation overlook the cyber kill chain and do not address any type of stealthy cyber attacks



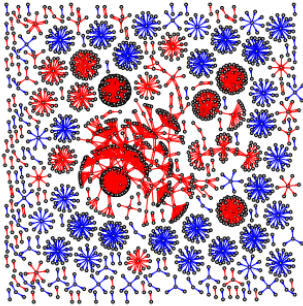


Traffic Dispersion Graphs

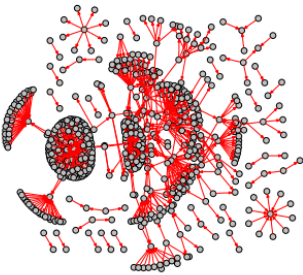
Traffic Dispersion Graph (TDG)



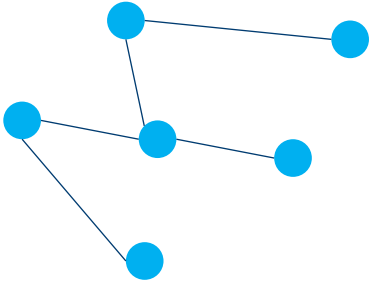
(a) All UDP flows excluding Slammer Worm (5 sec)



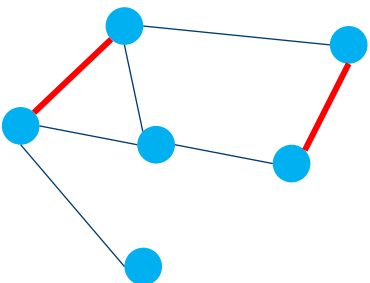
(b) All UDP flows including Slammer worm (5 sec)



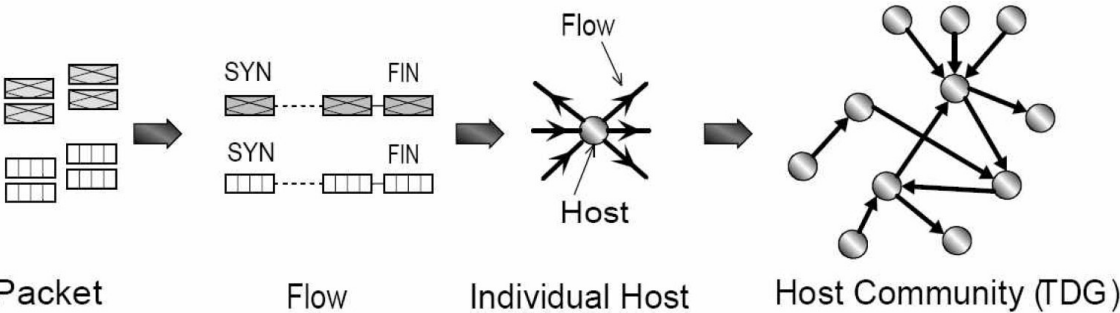
(c) DNS (5 sec)



Normal Traffic



Attack Traffic

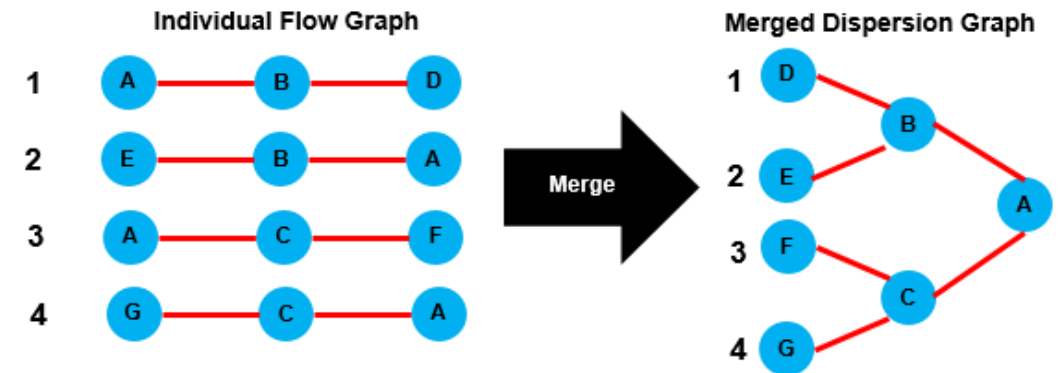


Traffic Dispersion Graph Process

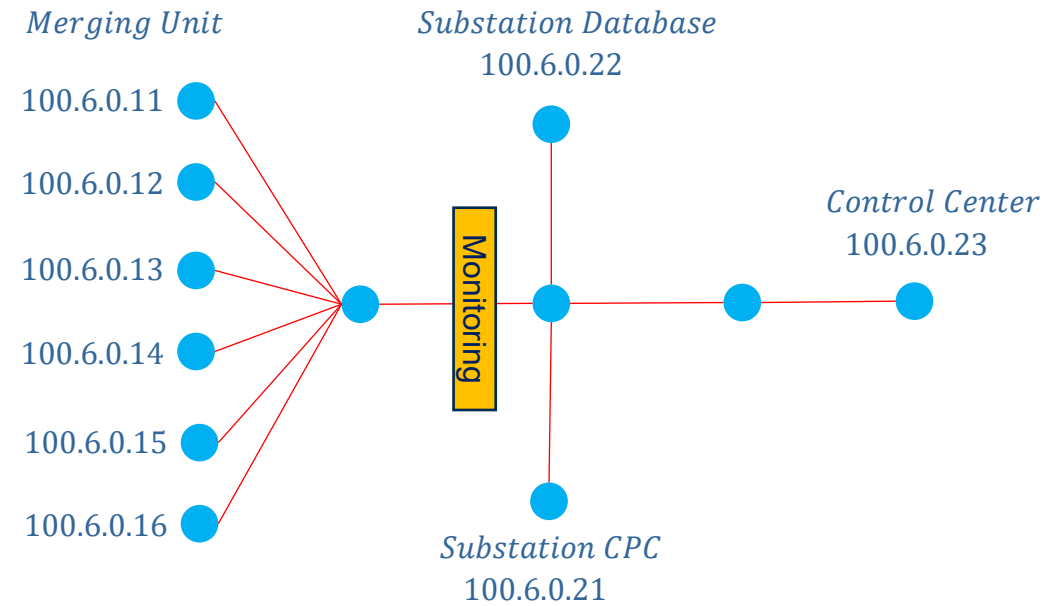
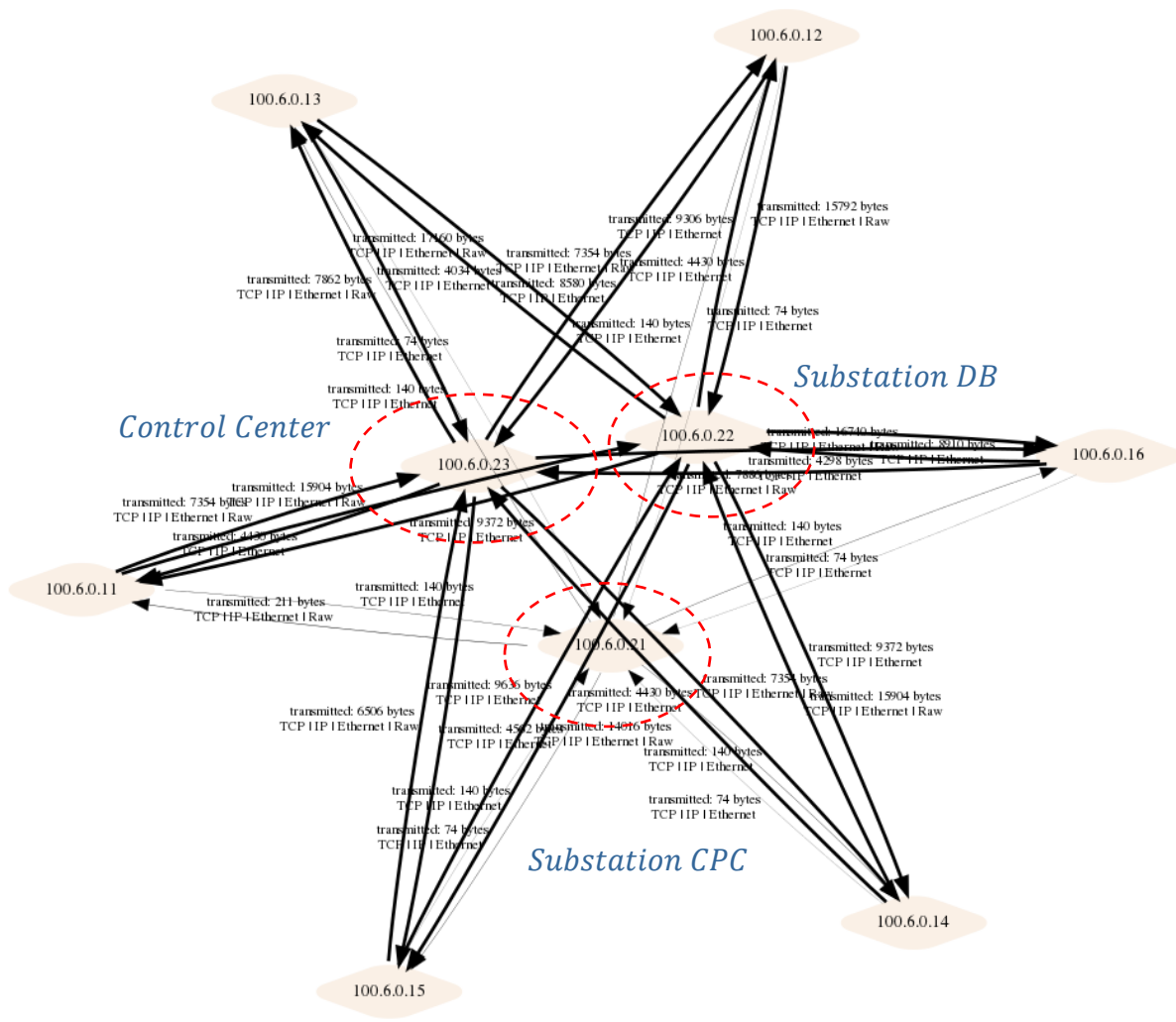
- Information on the IP address source and destination from flowing packets in the network is in the collected information table
- Information about the path between two IP addresses is added based on prior knowledge of the network topology
- The information in the table is then used to create an individual flow graph
- All individual graph is converged into a dispersion graph which provides an overall topology of the network

Collected Information Table

No	IP source	IP destination	Path
1	A	D	B
2	E	A	B
3	A	F	C
4	G	A	C



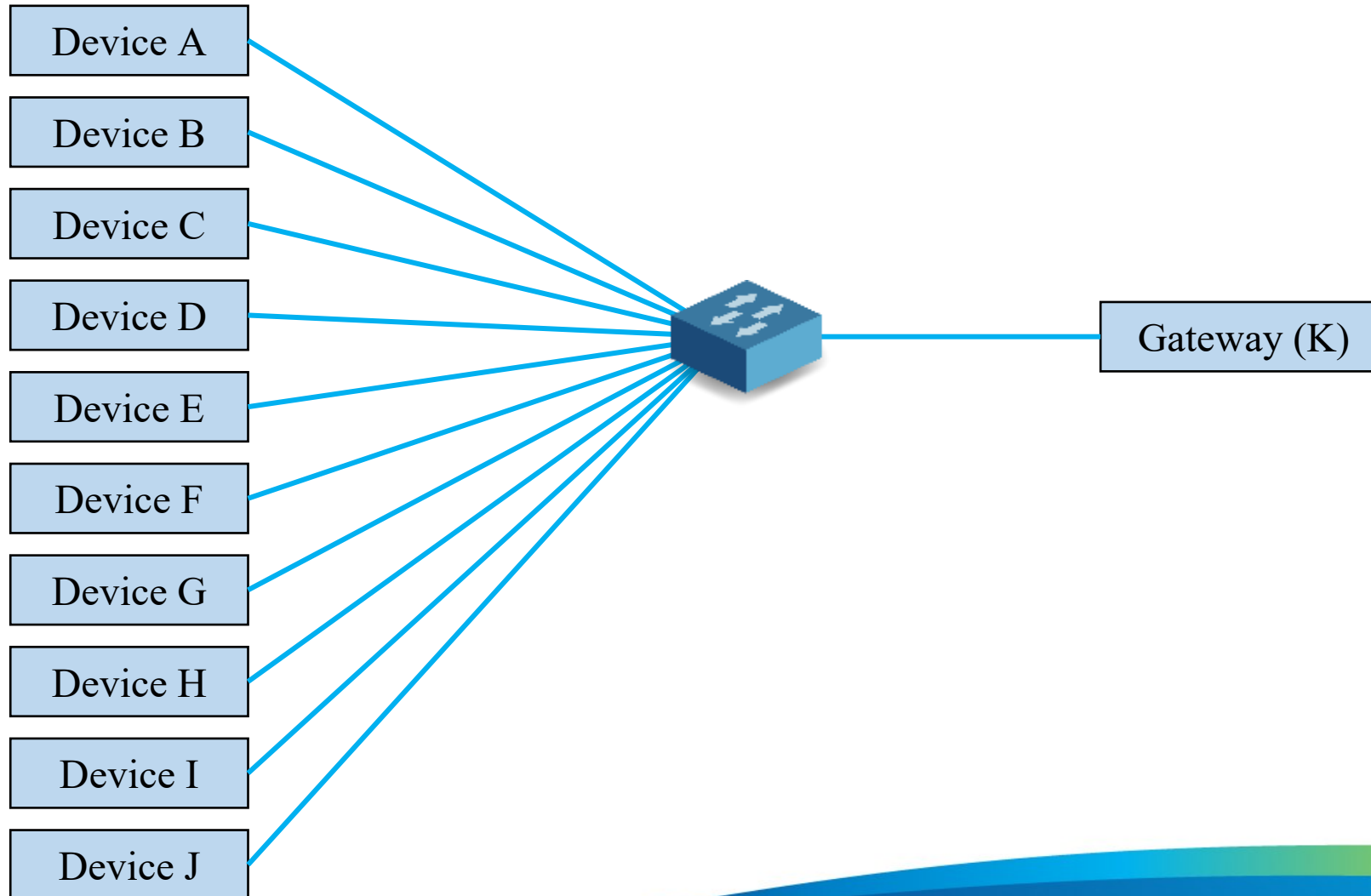
Traffic Dispersion Graph for Substation



Traffic Dispersion Graph

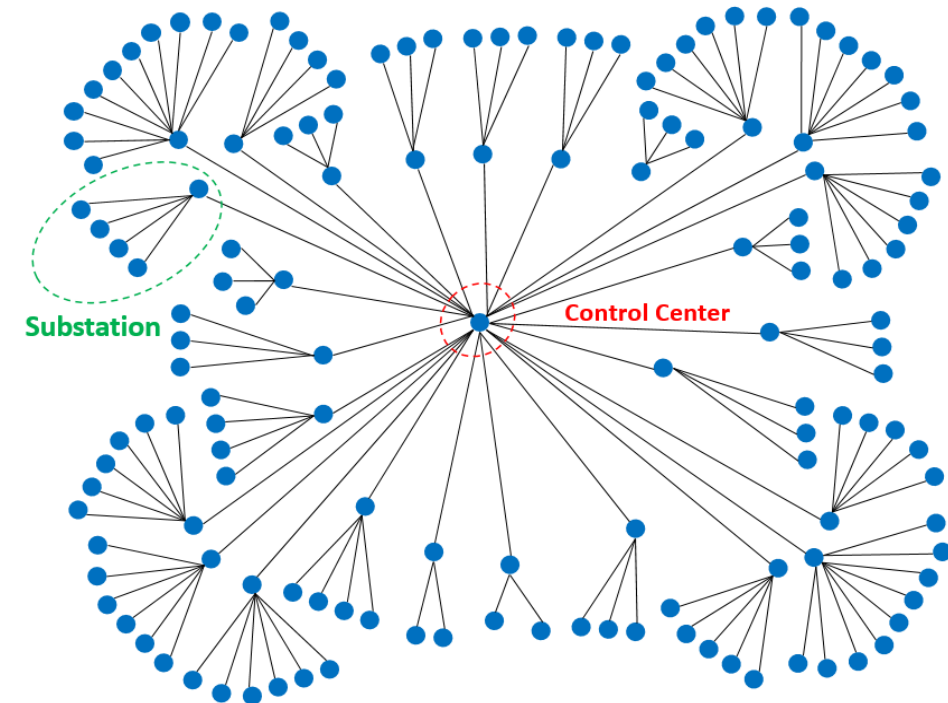
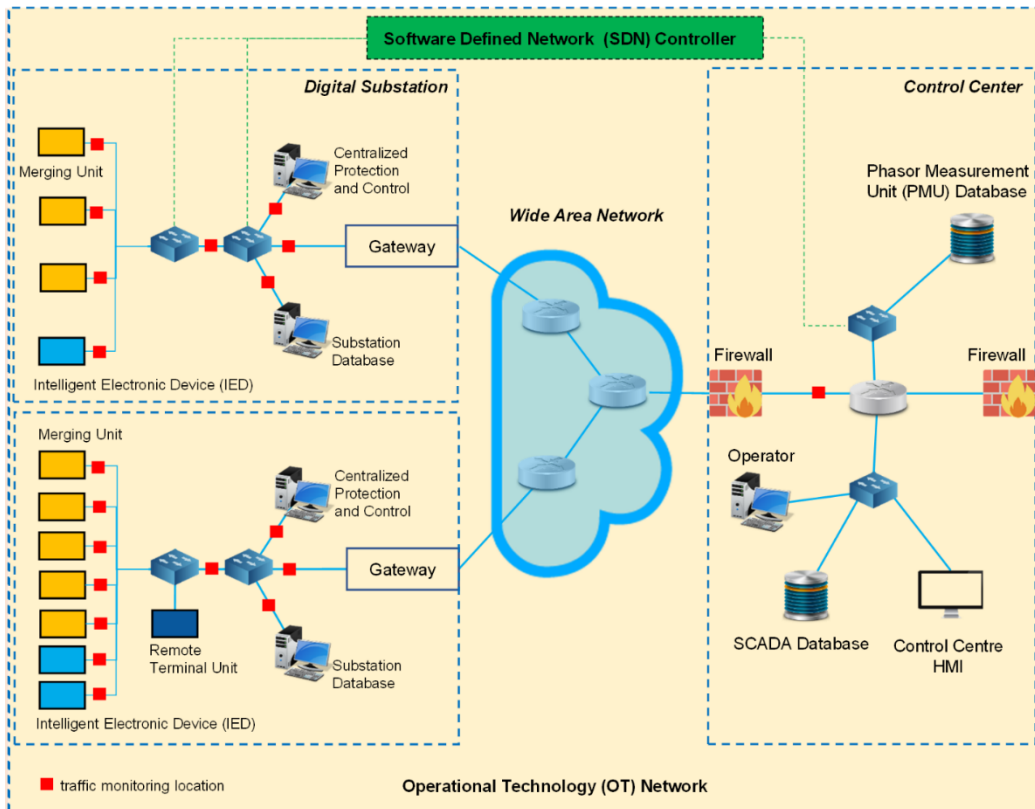
Substation Network Topology Graph

Network Topology for Lab Activities



Traffic Dispersion Graph for Entire OT Network

- The Traffic Dispersion Graph (TDG) is an analytical model for communication traffic monitoring and analysis.
- TDG represents network topological information using graph structures.





Lab 4: Operational Technology Network Traffic Analysis

Assignment

Part 1: Network Traffic Time-Series Analysis

1. Plot the traffic data from the provided CSV files.
 - a. Visualize and analyze all the protocols present in the dataset. (Hint: try using *scatter plots or heatmaps, boxplots or clustering*).
 - b. Limit the visualization to type GOOSE. Is the signal cyclic? Explain why or why not?
2. Perform resampling of the times-series data to merge the length of every x milliseconds and plot the result.
 - a. Plot different variations of resampling time in milliseconds, for example, $x = \{100, 200, 500, 1000, 2000\}$ etc.
 - b. Show the plot for the best resampling time for all protocols.
 - c. Show the plot for the best resampling time for GOOSE only.
3. Based on the plot results and CSV files, compare and comment on the characteristics and differences between IT and OT protocols.
4. Analyze and compare the traffic from all CSV files. Which file is most likely to contain anomalous traffic? Support your answers with representative plots.

Data

- No: 1,2,3 ...
- Time: 08:34:41.210994
- Source and Destination
- Protocols
- Length: [bytes]

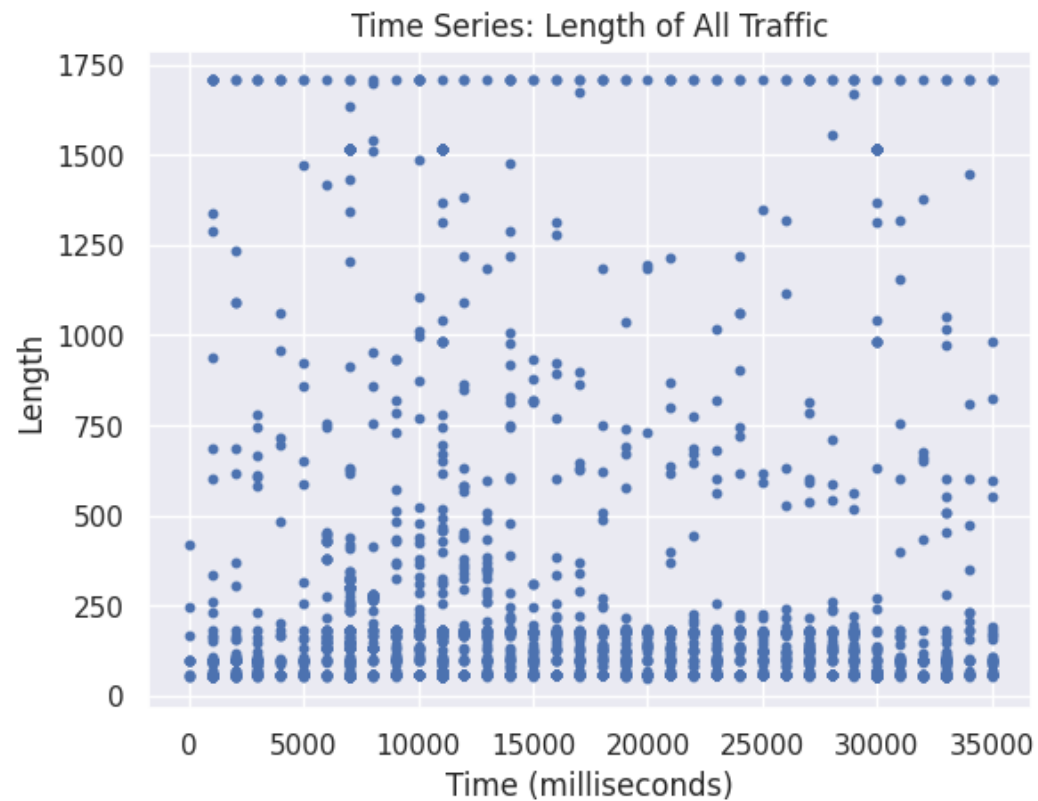
normal.csv

No.	Time	Source	Destination	Protocol	Length	Info
1	34:41.2	131.180.164.100	131.180.5.38	SMB2	306	Create Requi
2	34:41.2	131.180.164.100	131.180.5.38	SMB2	314	Create Requi
3	34:41.2	131.180.5.38	131.180.164.100	SMB2	298	Create Resp
4	34:41.2	131.180.5.38	131.180.164.100	SMB2	298	Create Resp
5	34:41.2	131.180.164.100	131.180.5.38	TCP	54	63329 > 44

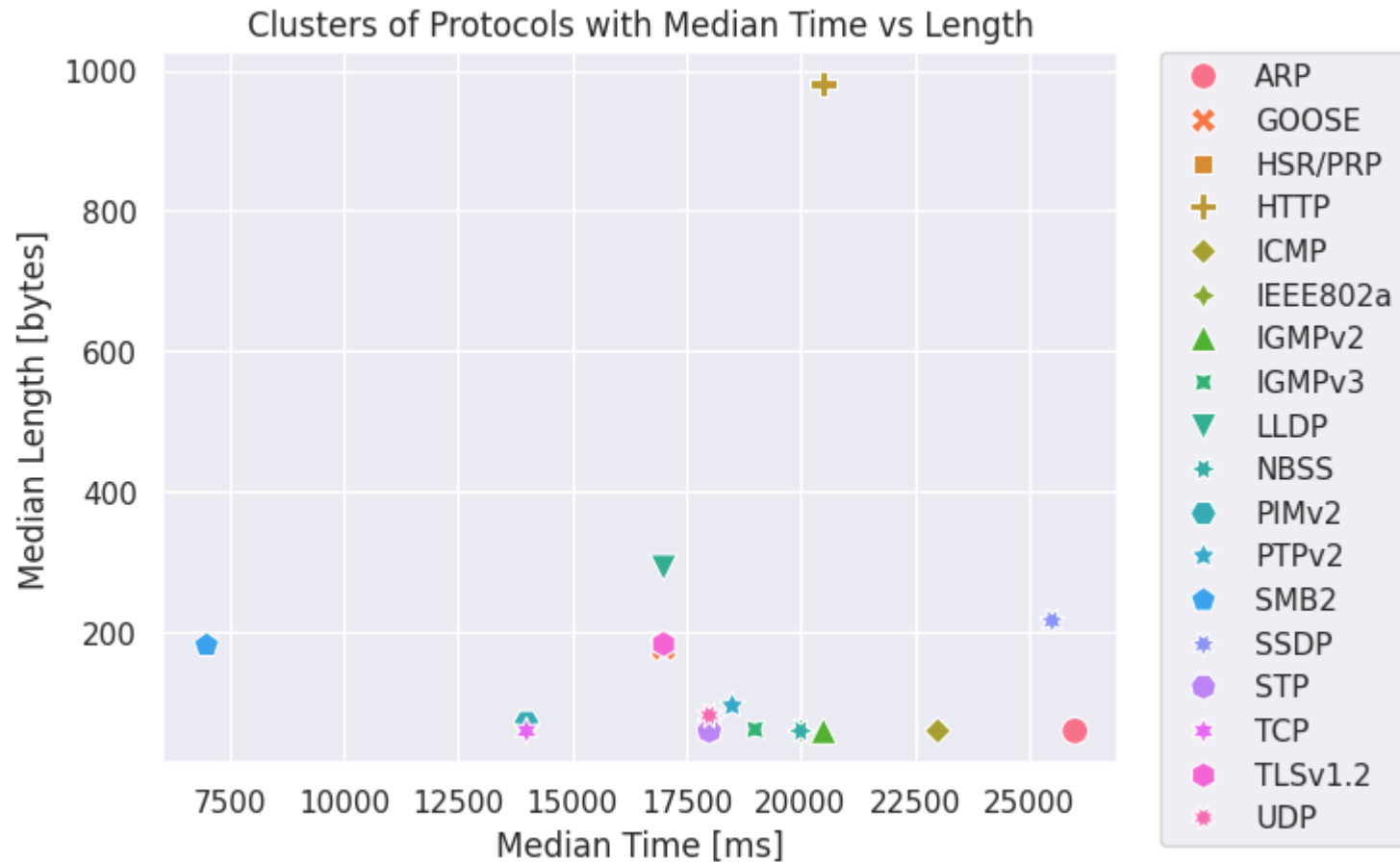
goose.csv

No.	Time	Source	Destination	Protocol	Length	Info
1	36:43.6	131.180.166.200	131.180.164.100	TCP	60	53829 > 3
2	36:43.7	131.180.166.200	131.180.164.100	TLSv1.2	97	Application
3	36:43.7	131.180.166.200	131.180.164.100	TLSv1.2	97	Application
4	36:43.7	131.180.164.100	131.180.166.200	TCP	54	3389 > 53
5	36:43.7	131.180.166.200	131.180.164.100	TLSv1.2	97	Application
6	36:43.8	131.180.166.200	131.180.164.100	TLSv1.2	97	Application
7	36:43.8	131.180.164.100	131.180.166.200	TCP	54	3389 > 53
8	36:43.8	SiemensE_05:30:6	lec-Tc57_01:00:01	GOOSE	169	

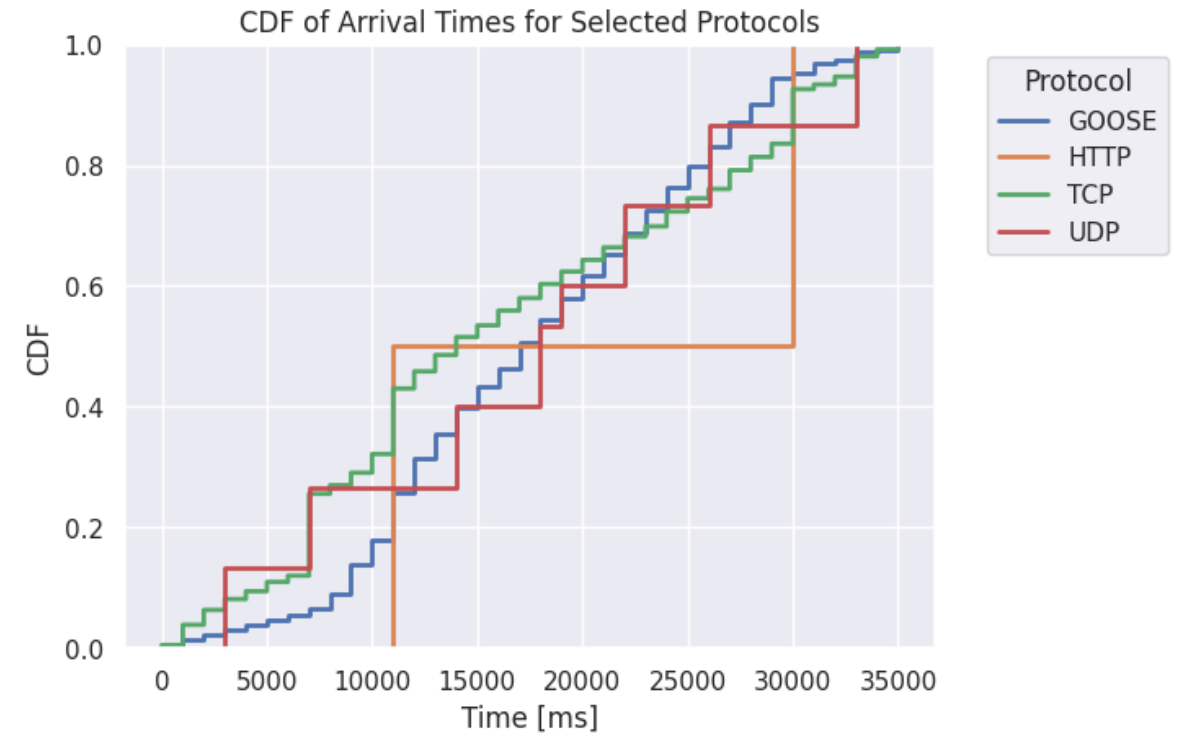
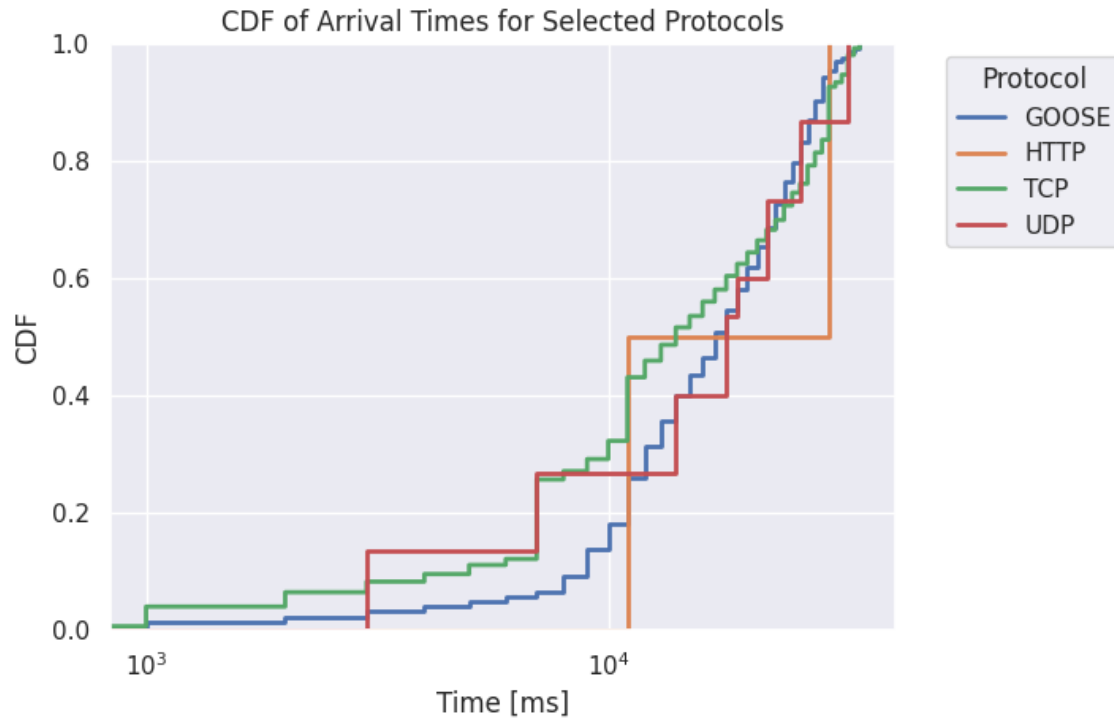
Time Series Data Plot



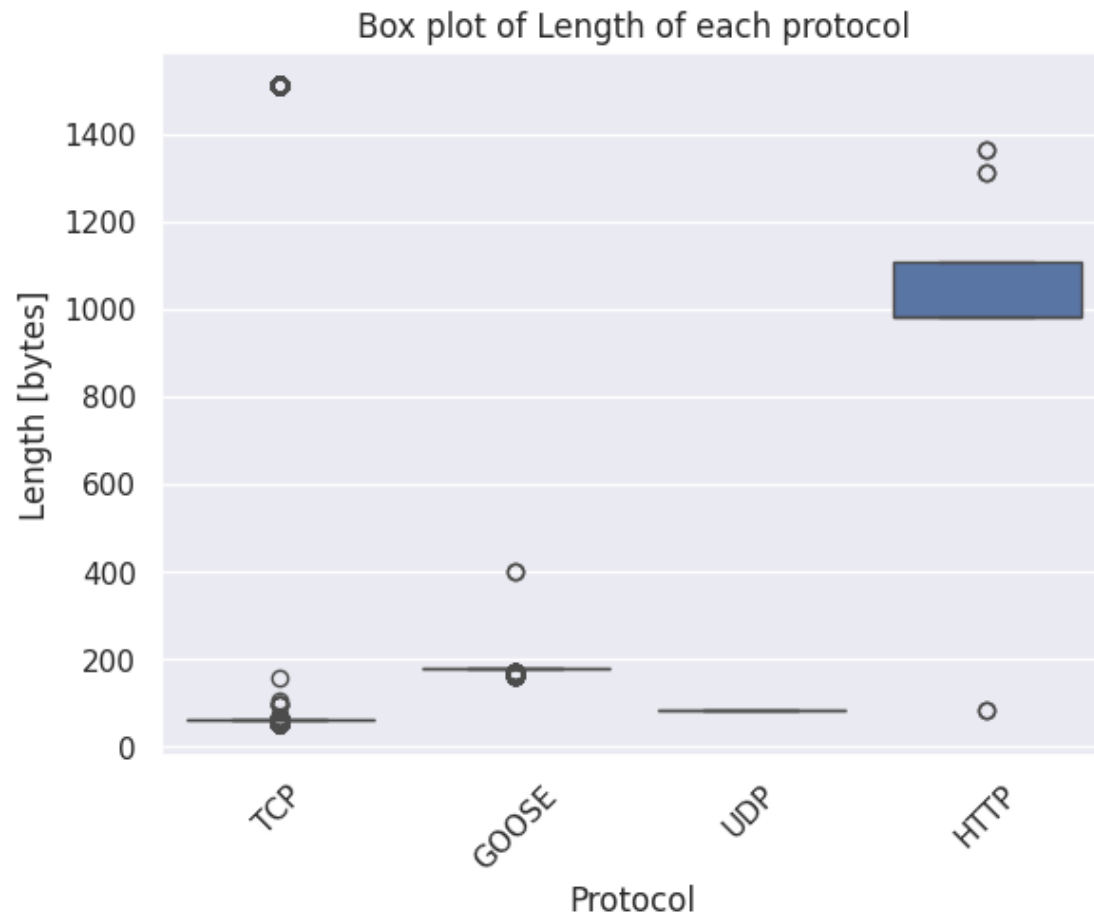
Traffic Characteristic – Length vs Time



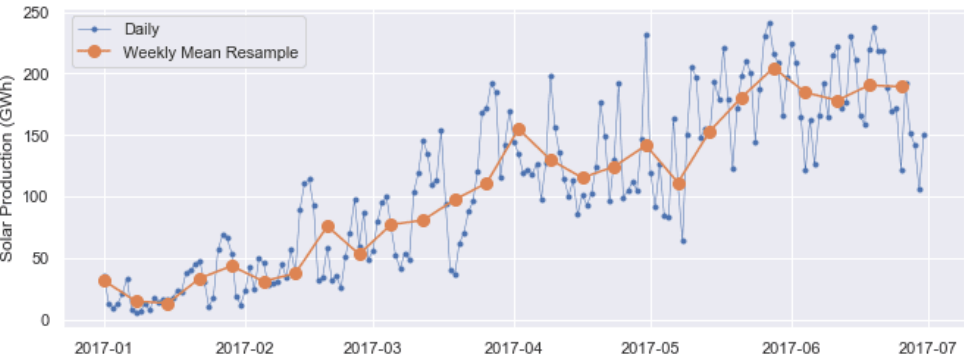
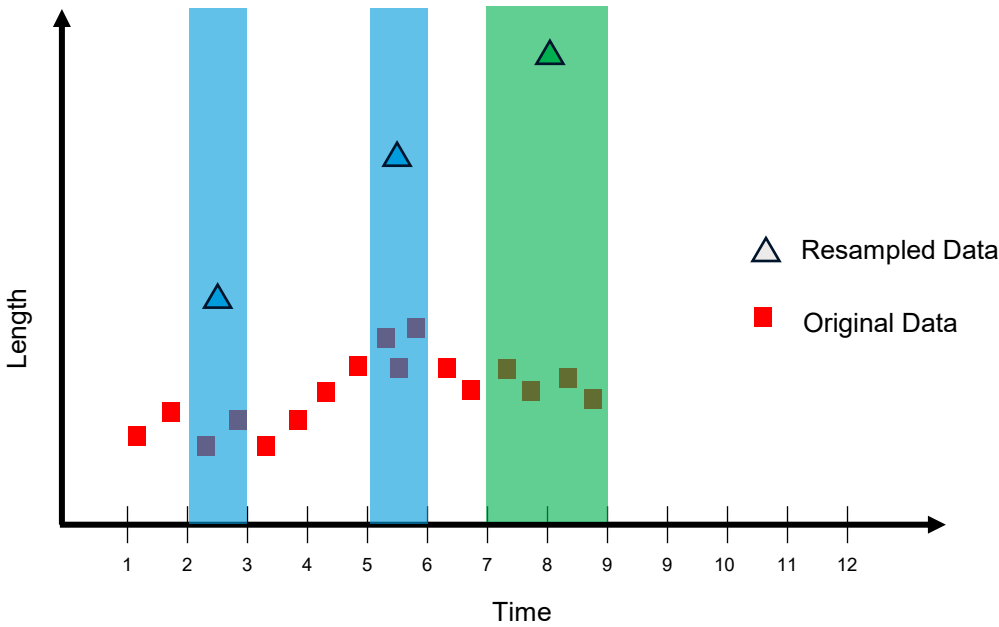
Traffic Characteristic – Empirical Cumulative Distribution Function



Traffic Characteristic – Length Box Plot



Traffic Characteristic – Resampled Traffic



Assignment

Part 2: Traffic Dispersion Graph

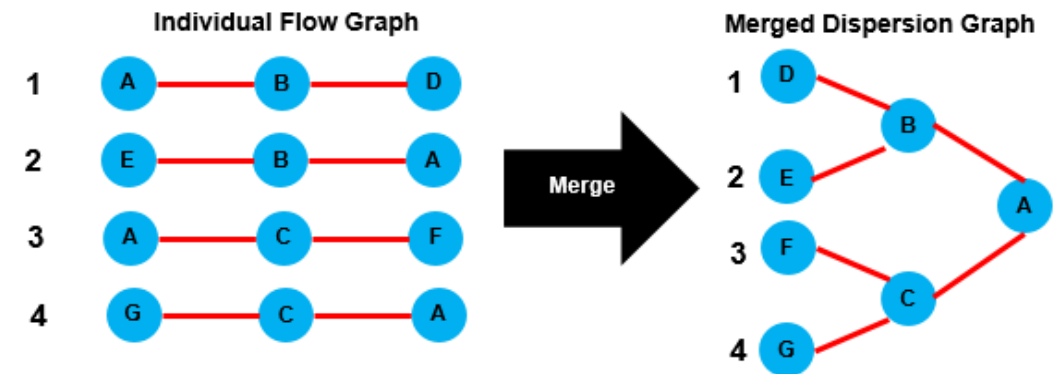
1. Plot graphs from the CSV files using Networkx. Combination of sources and destinations in the CSV files serve as edge lists for the Networkx graph.
2. Modify the graph by adding switch nodes, such that all traffic flows via the switch node.
3. How many total nodes/devices exist for each graph?
4. Briefly identify and explain the node characteristics for each graph.

Traffic Dispersion Graph Process

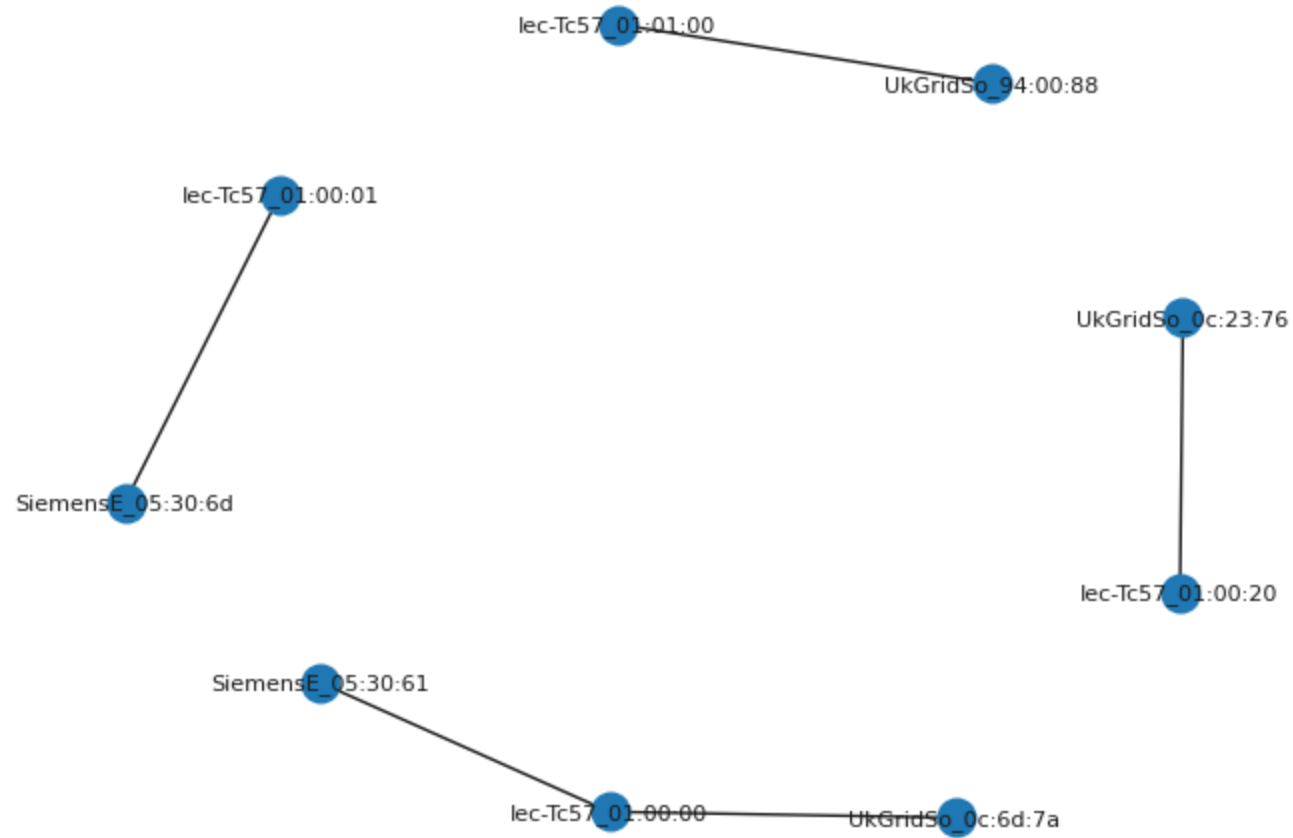
- Information on the IP address source and destination from flowing packets in the network is in the collected information table
- Information about the path between two IP addresses is added based on prior knowledge of the network topology
- The information in the table is then used to create an individual flow graph
- All individual graph is converged into a dispersion graph which provides an overall topology of the network

Collected Information Table

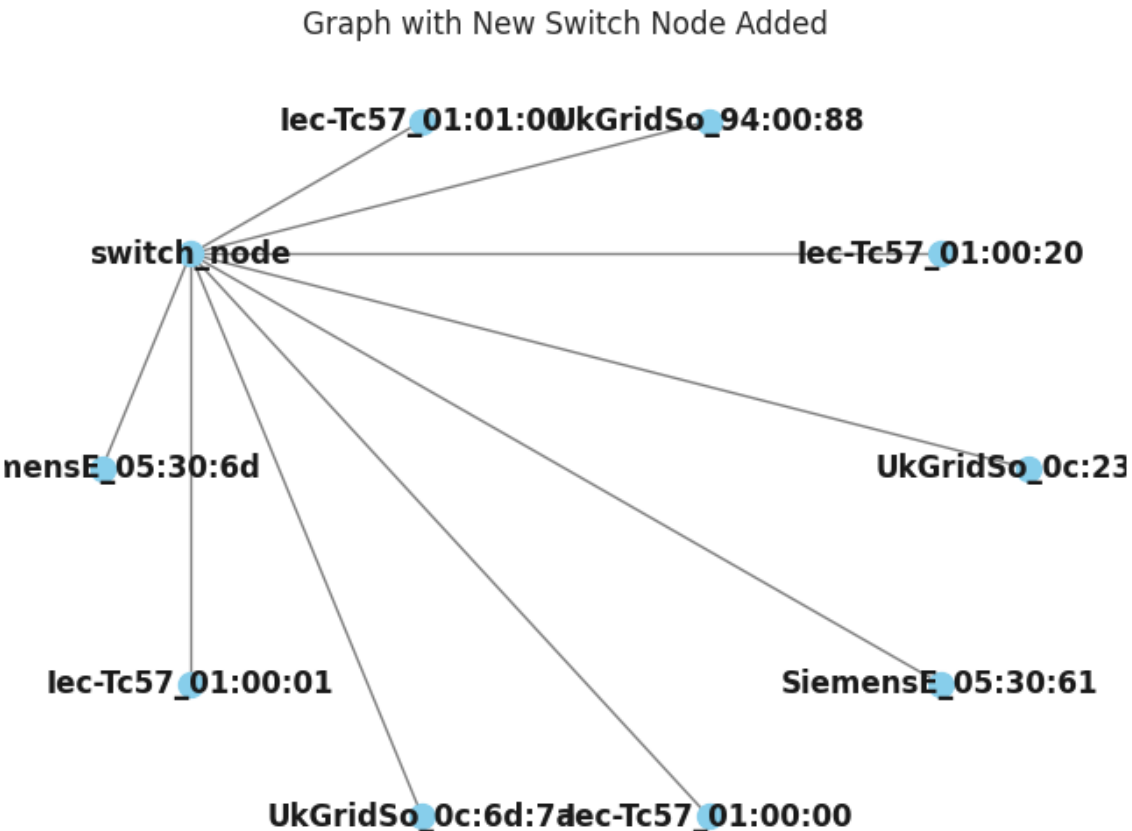
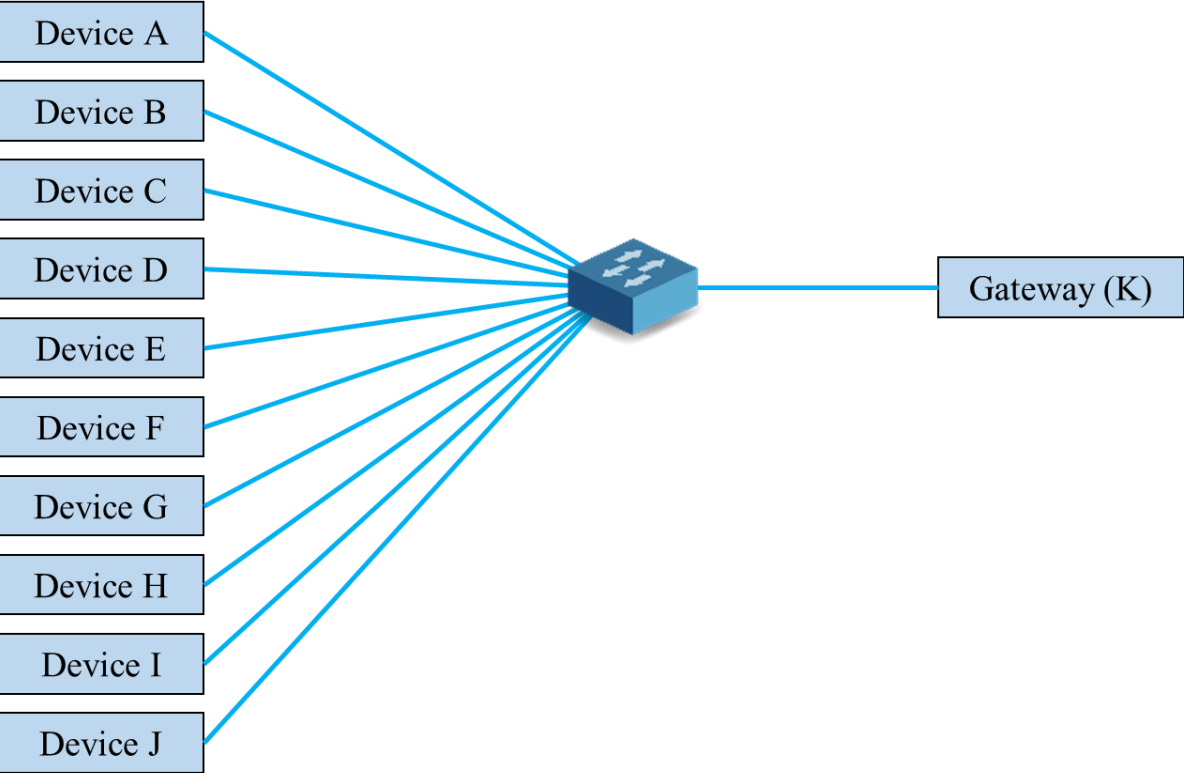
No	IP source	IP destination	Path
1	A	D	B
2	E	A	B
3	A	F	C
4	G	A	C



Traffic Dispersion Graph Plot



Traffic Dispersion Graph Plot with Switch





GET IN
TOUCH

Alex Stefanov

Assistant Professor, Chartered Engineer (CEng MIEI)

Email: A.I.Stefanov@tudelft.nl

Cyber Resilient Power Grids ([LinkedIn](#))

Control Room of the Future ([LinkedIn](#))

Intelligent Electrical Power Grids, EEMCS, **TU Delft**
Mekelweg 4, 2628 CD Delft, The Netherlands